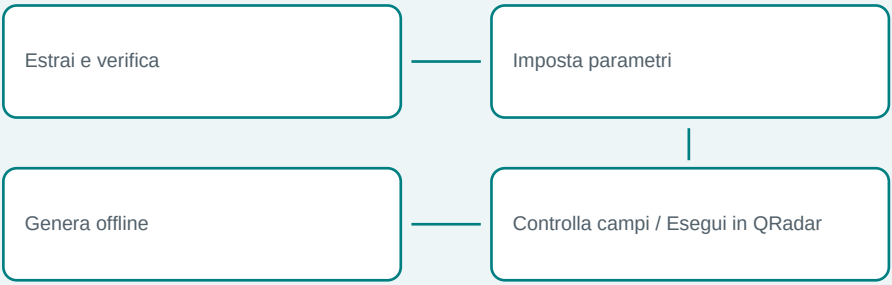
QRADAR / BLUE TEAM

# Manuale operativo

117 template AQL. Evidenze prima delle ipotesi. Dal triage all’hunting approfondito.



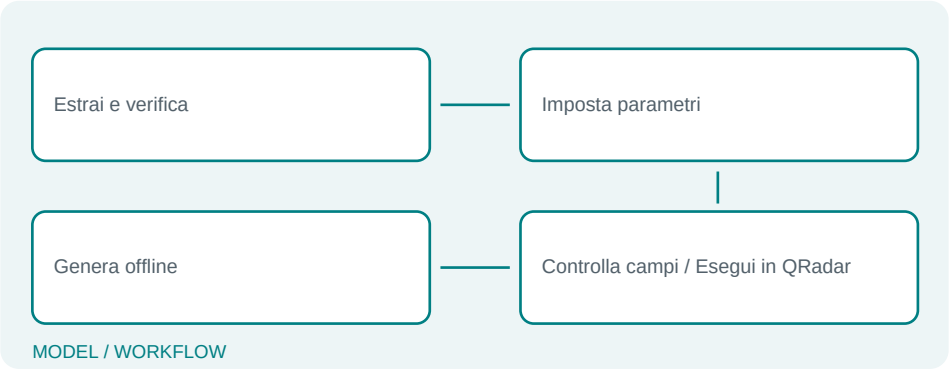

MODEL / WORKFLOW

## Public edition 2.0.0 / Italiano

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Come usare il fieldbook

Parti da Q016 per ispezionare un evento noto, poi scegli un pivot preciso per IP, utente o tempo. I livelli rapido/intermedio/avanzato descrivono la complessità analitica, non un tempo garantito.

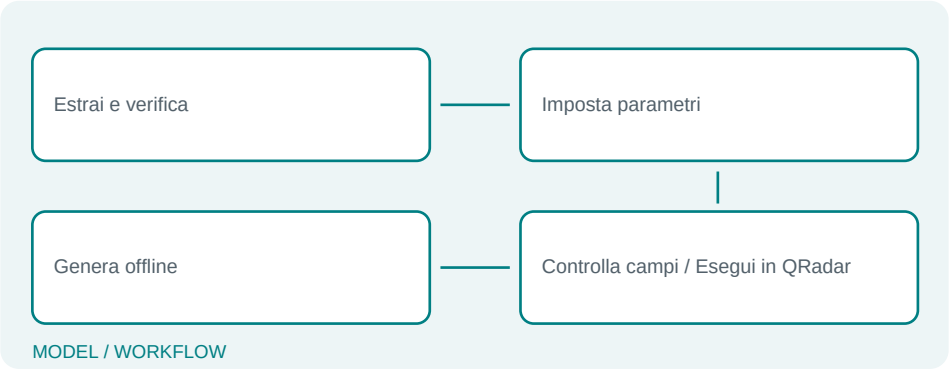



MODEL / WORKFLOW

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# AQL e interfaccia

Log Activity per FROM events; Network Activity per FROM flows. GLOBALVIEW richiede una vista accumulata esistente e il percorso API documentato. Qui AQL significa Ariel Query Language, non il linguaggio di altri prodotti.

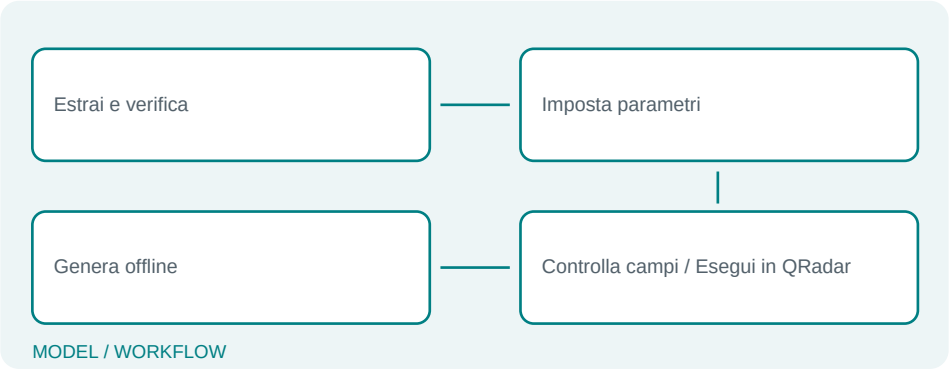



MODEL / WORKFLOW

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Parametri e campi

Sostituisci ogni <PARAMETRO> tramite renderer o modifica manuale revisionata. I nomi Hunt_* sono convenzioni proposte: rimappali su proprietà reali o configurali tramite il gestore autorizzato.

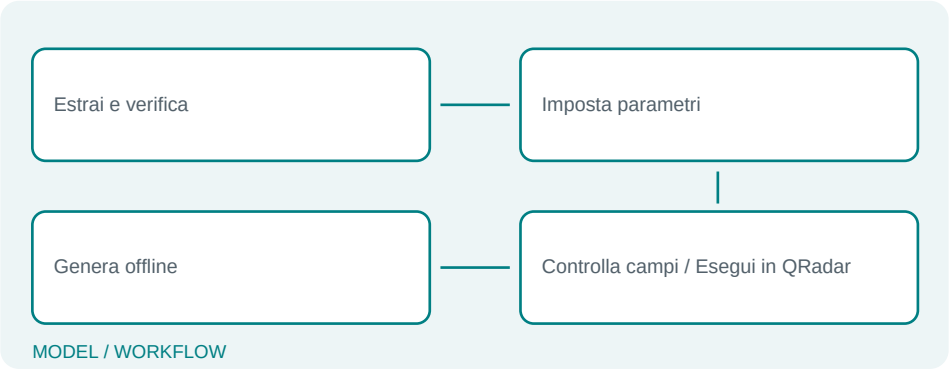



MODEL / WORKFLOW

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Tempo e identità

Documenta timezone della console, finestra assoluta e conversione UTC. username può indicare attore o soggetto: verifica il raw prima di correlare identità. QID non è un Windows Event ID.

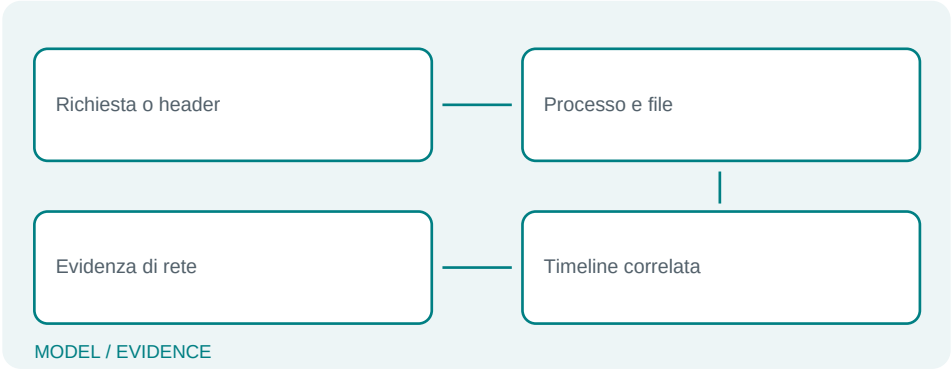



MODEL / WORKFLOW

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Livelli di evidenza

Richiesta, firewall allow, HTTP 200, logon riuscito, processo eseguito e file trasferito sono osservazioni diverse. Correlale tramite host, tempo e identificatori attendibili prima di formulare una catena causale.

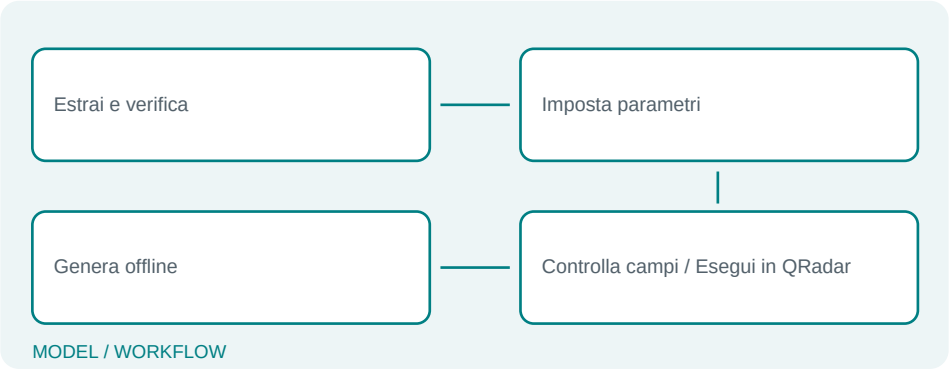



MODEL / EVIDENCE

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Risultati negativi

Zero righe significa nessuna corrispondenza entro scope, permessi, parsing e retention della ricerca. Verifica un evento positivo noto prima di usare l’assenza come evidenza.

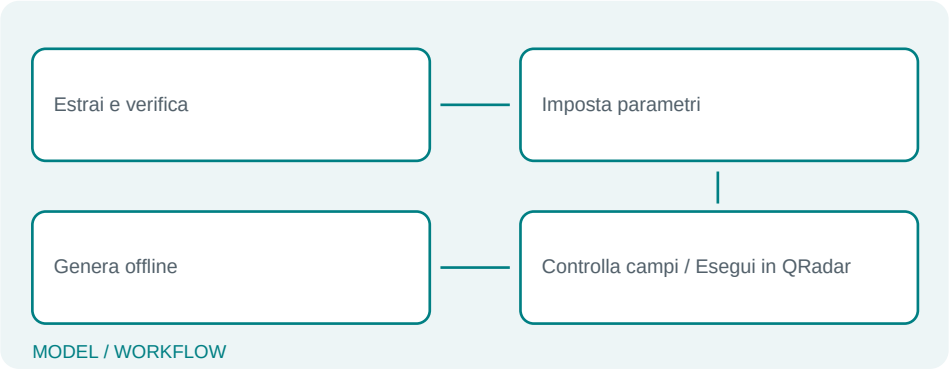



MODEL / WORKFLOW

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Scenari pubblici

Gli esempi sono ipotetici e parametrizzati. Non vengono forniti incidenti privati, identità istituzionali, account, segreti o IOC verificati di campagne. Le query per prodotto sono candidati di hunting, non firme exploit convalidate.

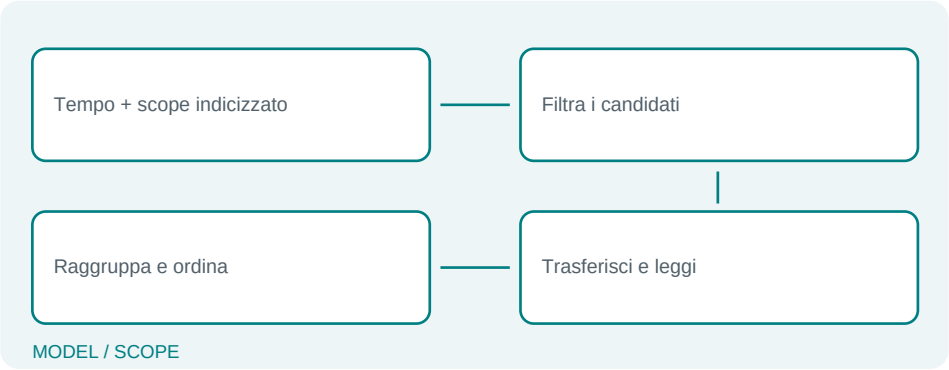



MODEL / WORKFLOW

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Prestazioni

Usa filtri tempo/sorgente motivati, campi normalizzati esatti e poche colonne quando mantengono la domanda. LIMIT limita l’output, non garantisce una scansione breve. Un indice aiuta dove esiste ed è applicabile.

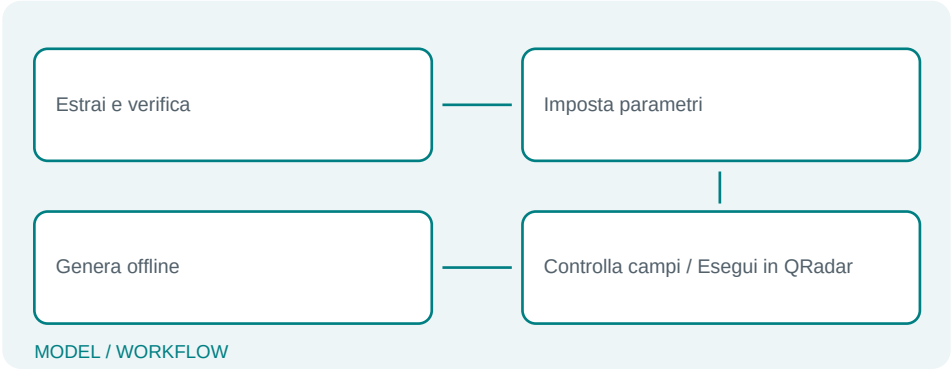



MODEL / SCOPE

Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Riutilizzo

Il renderer produce testo: non esegue AQL, non si collega a QRadar, non installa contenuti e non crea job. Revisiona la query e mappa le proprietà prima dell’esecuzione.




Template confrontati con documentazione e controllati offline. Non sono stati analizzati dal parser né eseguiti sulla tua installazione QRadar. Campi DSM, build, permessi e retention richiedono validazione locale.

# Indice delle query

**Q001** Timeline essenziale di un IP

**Q002** Account esatto o indirizzo email

**Q003** Email nel testo grezzo

**Q004** Eventi collegati a una offense

**Q005** Offense con finestra ottimizzata

**Q006** Quali sorgenti vedono questo IP?

**Q007** Eventi dominanti per QID

**Q008** Deny verso una singola destinazione

**Q009** Esiti misti sullo stesso percorso

**Q010** Ricerca testuale indicizzata

**Q011** Dominio esatto nei DNS

**Q012** URL, Host e User-Agent

**Q013** Dettaglio flussi con un IP

**Q014** Ultimo evento di una sorgente

**Q015** Finestra assoluta riproducibile

**Q016** Anteprima del raw della sorgente

**Q017** Password spray per sorgente

**Q018** Brute force su un account

**Q019** Successi ed errori dello stesso utente

**Q020** Accessi RDP e credenziali esplicite

# Indice delle query

**Q021** Nuovi account e riabilitazioni

**Q022** Reset password e account modificati

**Q023** Aggiunta a gruppi sensibili

**Q024** Privilegi speciali su nuovi logon

**Q025** Ticket Kerberos: volume anomalo

**Q026** Preautenticazione Kerberos fallita

**Q027** Modifiche alle directory

**Q028** Operazioni directory da verificare

**Q029** Audit cancellato o policy cambiata

**Q030** Account di servizio usato da molte origini

**Q031** Autenticazioni IdP da IP e utenti

**Q032** Modifiche OAuth, consenso e credenziali

**Q033** Scansione verticale di porte

**Q034** Scansione orizzontale di host

**Q035** Movimento laterale da un server

**Q036** LDAPS negato: il caso porta 636

**Q037** Egress escluso dalle reti note

**Q038** Trasferimenti prevalentemente in uscita

**Q039** Volume piccolo e ripetuto: candidati C2

**Q040** Timeline per verificare un beacon

# Indice delle query

**Q041** DNS con molti nomi distinti

**Q042** DNS NXDOMAIN per client

**Q043** DNS con etichette molto lunghe

**Q044** Connessioni a resolver non approvati

**Q045** SMB o amministrazione verso l’esterno

**Q046** IP prima e dopo NAT

**Q047** Traffico VPN/DTLS da verificare

**Q048** BGP flap e reset di sessione

**Q049** Shell generata da Office

**Q050** Shell figlia di server Java

**Q051** PowerShell con argomenti codificati

**Q052** LOLBins con destinazioni remote

**Q053** msiexec e il falso positivo Citrix PVS

**Q054** Accesso a LSASS da processi insoliti

**Q055** Nuovi servizi e scheduled task

**Q056** Persistenza Unix nei log audit

**Q057** Download seguito da shell

**Q058** Tunnel e inoltri remoti

**Q059** Nuovo JSP scritto nel webroot

**Q060** Richieste verso file server-side sospetti

# Indice delle query

**Q061** Errori HTTP per endpoint

**Q062** Traversal in URI, anche codificato

**Q063** Attività Kubernetes amministrativa

**Q064** Rimozione log e disattivazione controlli

**Q065** Numero di righe contro numero di eventi

**Q066** Volume per bucket di cinque minuti

**Q067** Ritardo tra device e storage

**Q068** IP in reference set di hunting

**Q069** Enrichment dell’asset da mappa

**Q070** Tabella utenti: ruolo e reparto

**Q071** Host non autorizzati per account di servizio

**Q072** Successi per utenti con fallimenti recenti

**Q073** Sorgenti rare nella finestra

**Q074** Nuove destinazioni rispetto alla baseline

**Q075** Rapporto allow/deny con CASE

**Q076** Sottoquery FROM su candidati aggregati

**Q077** Accesso a dati accumulati GLOBALVIEW

**Q078** Identificare QID con parsing insufficiente

**Q079** Copertura di una proprietà custom

**Q080** Distribuzione dei dati tra domini

# Indice delle query

**Q081** Pivot su un IP indicatore parametrico

**Q082** WSO2: accessi a /fileupload

**Q083** WSO2: tracce upload e deployment

**Q084** IdP: chiamate SCIM e provisioning

**Q085** Pattern di comandi negli header SMTP

**Q086** Marker generici di comando e staging mail

**Q087** Contatti gateway mail verso un IOC fornito

**Q088** ESA: management e quarantine esposti

**Q089** Exchange: superfici web e PowerShell

**Q090** Exchange: worker web che genera shell

**Q091** Exchange ibrido: principal e certificati

**Q092** Outlook: figli di processo da investigare

**Q093** Allegati OneNote e dominio parametrico

**Q094** Pivot su User-Agent HTTP fornito

**Q095** Pivot DNS su domini forniti

**Q096** Endpoint RPC blockchain condivisi

**Q097** NetScaler: crash e modifiche sospette

**Q098** WSO2 2026: esiti JWT e autenticazione

**Q099** WSO2 2026: problemi del throttling

**Q100** Email gateway: anomalie oltre le firme

# Indice delle query

**Q101** OpenBMC/IPMI: origini verso UDP 623

**Q102** Wing FTP: NUL codificato e log sessione

**Q103** Pivot richieste e sessioni ZoneMinder

**Q104** Expressway: accessi al servizio di cluster

**Q105** FortiOS: errori del servizio e modifiche

**Q106** Webex e porta 9000: verifica del contesto

**Q107** SNMP e NetBIOS da un host

**Q108** Stessa sessione IdP da IP diversi

**Q109** Regola WAF: riscontro con esito e path

**Q110** WSO2 VS Code: processi di test inattesi

# Q001 / Timeline essenziale di un IP

01 · Triage rapido / Rapida / Basso

## Prerequisiti

Eventi normalizzati; IP osservato al punto di raccolta.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE sourceip = '<IP>' OR destinationip = '<IP>'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Controlla QID, sorgente del log e direzione. Allarga il tempo solo dopo un campione utile.

## Limiti e falsi positivi

Gli IP dentro URL, NAT o campi custom non rientrano automaticamente nel filtro.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S01, S02

# Q002 / Account esatto o indirizzo email

01 · Triage rapido / Rapida / Basso

### Prerequisiti

username valorizzato dal DSM; usare UPN, DOMINIO\utente o email nella forma realmente raccolta.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE username ILIKE '<USER>'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Parti dal valore esatto. Ripeti con le forme alternative osservate, senza dedurre identità dal solo mittente email.

### Limiti e falsi positivi

ILIKE senza percentuali è confronto senza distinzione di maiuscole; username può indicare attore o soggetto secondo il DSM.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S01, S02

# Q003 / Email nel testo grezzo

01 · Triage rapido / Rapida / Alto

### Prerequisiti

Log mail con indirizzi nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_MAIL>
  AND UTF8(payload) ILIKE '%<EMAIL>%'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Individua ruolo dell’indirizzo: sender, recipient, account o testo del messaggio.

### Limiti e falsi positivi

La presenza di una email non prova creazione, accesso o possesso dell’account.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: S03, S09

# Q004 / Eventi collegati a una offense

01 · Triage rapido / Rapida / Medio

## Prerequisiti

ID numerico della offense e retention compatibile.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE INOFFENSE(<OFFENSE_ID>)
ORDER BY starttime ASC
LIMIT 500 LAST 24 HOURS
```

## Leggere il risultato

Confronta con vista offense; estendi la finestra se l'inizio è precedente alle ultime 24 ore.

## Limiti e falsi positivi

Associazione alla offense non equivale a causalità; dominio e permessi limitano la visibilità.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S04

# Q005 / Offense con finestra ottimizzata

01 · Triage rapido / Avanzata / Medio

### Prerequisiti

Versione/build che supporta OFFENSE_TIME; verificare eventuali APAR.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE INOFFENSE(<OFFENSE_ID>)
TIMES OFFENSE_TIME(<OFFENSE_ID>)
```

### Leggere il risultato

TIMES è la sintassi documentata: non sostituirla con START OFFENSE_TIME. Confronta Q004 su un caso noto.

### Limiti e falsi positivi

Ottimizza la finestra; non supera retention, autorizzazioni o difetti della build.

### Ridurre il lavoro di ricerca

Confronta con Q004 sullo stesso insieme temporale. OFFENSE_TIME restringe i tempi applicabili; verifica risultati e build prima di affidargli ricerche salvate.

Riferimenti: S04, S13

# Q006 / Quali sorgenti vedono questo IP?

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Campi standard events.

```
SELECT logsourceid, LOGSOURCENAME(logsourceid) AS Fonte,
       COUNT(*) AS Righe, SUM(eventcount) AS Eventi
FROM events
WHERE sourceip = '<IP>' OR destinationip = '<IP>'
GROUP BY logsourceid
ORDER BY Eventi DESC
LAST 60 MINUTES
```

### Leggere il risultato

Un firewall e un EDR danno prove diverse: scegli la prossima query dalla fonte disponibile.

### Limiti e falsi positivi

COUNT(*) conta righe Ariel; SUM(eventcount) include la coalescenza.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S05, S14

# Q007 / Eventi dominanti per QID

01 · Triage rapido / Rapida / Basso

### Prerequisiti

QID mapping del DSM.

```
SELECT qid, QIDNAME(qid) AS Evento,
       SUM(eventcount) AS Totale
FROM events
WHERE sourceip = '<IP>'
GROUP BY qid
ORDER BY Totale DESC
LIMIT 30 LAST 60 MINUTES
```

### Leggere il risultato

Controlla alcuni raw per ciascun QID prevalente prima di definire successo o blocco.

### Limiti e falsi positivi

QID numerico è QRadar, non Windows Event ID e non CVE.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S01, S02

# Q008 / Deny verso una singola destinazione

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Hunt_Action custom string, normalizzata ai valori indicati.

```
SELECT sourceip, destinationip, destinationport,
       "Hunt_Action", SUM(eventcount) AS Totale
FROM events
WHERE logsourceid = <LS_FW>
  AND sourceip = '<IP>'
  AND "Hunt_Action" IN ('deny','drop','blocked')
GROUP BY sourceip, destinationip, destinationport,
         "Hunt_Action"
ORDER BY Totale DESC
LAST 60 MINUTES
```

### Leggere il risultato

Distingui retry, scansione e errore di configurazione con intervalli e porte.

### Limiti e falsi positivi

I vocaboli del vendor vanno mappati; un deny non dimostra raggiungimento dell’applicazione.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q009 / Esiti misti sullo stesso percorso

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Log firewall con decisione normalizzata.

```
SELECT "Hunt_Action", destinationport,
       COUNT(*) AS Righe, SUM(eventcount) AS Totale
FROM events
WHERE logsourceid = <LS_FW>
  AND sourceip = '<IP>' AND destinationip = '<DST>'
GROUP BY "Hunt_Action", destinationport
ORDER BY Totale DESC
LAST 60 MINUTES
```

### Leggere il risultato

Se esistono allow dopo deny verifica session ID, NAT e policy; non aggregare sessioni diverse come un singolo tentativo.

### Limiti e falsi positivi

Allow è decisione del controllo, non prova di autenticazione o exploit riuscito.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q010 / Ricerca testuale indicizzata

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Indice full text e termine verificato con un evento noto.

```
SELECT starttime, sourceip, QIDNAME(qid) AS Evento,
       UTF8(payload) AS Raw
FROM events
WHERE TEXT SEARCH '<TERM>'
  AND logsourceid = <LS_ID>
LIMIT 100 LAST 15 MINUTES
```

### Leggere il risultato

TEXT SEARCH va per primo nella WHERE ed è combinato qui soltanto con AND.

### Limiti e falsi positivi

Tokenizzazione e punteggiatura influenzano i match; non equivale sempre a una sottostringa ILIKE.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S06

# Q011 / Dominio esatto nei DNS

01 · Triage rapido / Rapida / Basso

### Prerequisiti

DNS client/resolver con nome canonico senza punto finale; rimappare se il log conserva il punto.

```
SELECT starttime, sourceip, "Hunt_DNSName",
       "Hunt_DNSRcode", UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_DNS>
  AND "Hunt_DNSName" ILIKE '<DOMAIN>'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Attribuisci l’IP al client reale: il resolver centrale può apparire come sorgente.

### Limiti e falsi positivi

Il dominio risolto non prova download o esecuzione; cache e DNS cifrato riducono copertura.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: S09

# Q012 / URL, Host e User-Agent

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Access log/proxy/WAF con HTTP in chiaro o terminazione TLS.

```
SELECT starttime, sourceip, "Hunt_HTTPHost",
       "Hunt_URI", "Hunt_UserAgent", "Hunt_Status"
FROM events
WHERE logsourceid = <LS_WEB>
  AND sourceip = '<IP>'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Ricostruisci sequenza di path, metodo, codici e sessione.

### Limiti e falsi positivi

HTTP 200 può essere pagina di errore o challenge; User-Agent si può falsificare.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S09

# Q013 / Dettaglio flussi con un IP

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Network Activity; NetFlow/IPFIX/QFlow realmente presenti.

```
SELECT starttime, sourceip, sourceport,
       destinationip, destinationport,
       PROTOCOLNAME(protocolid) AS Protocollo,
       sourcebytes, destinationbytes
FROM flows
WHERE sourceip = '<IP>' OR destinationip = '<IP>'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Verifica orientamento sorgente/destinazione e possibili segmenti della stessa connessione.

### Limiti e falsi positivi

Byte TLS e porta 443 non rivelano URI o contenuto.

### Ridurre il lavoro di ricerca

Interroga IP e intervallo già motivati; seleziona tuple, tempo e byte necessari. Ampliare le porte o aggiungere più reti può aumentare il costo; cambiare scope deve restare dichiarato.

Riferimenti: S07

# Q014 / Ultimo evento di una sorgente

01 · Triage rapido / Rapida / Basso

### Prerequisiti

ID della sorgente; ora console nota.

```
SELECT logsourceid, LOGSOURCENAME(logsourceid) AS Fonte,
       MAX(starttime) AS Ultimo,
       SUM(eventcount) AS Eventi
FROM events
WHERE logsourceid = <LS_ID>
GROUP BY logsourceid
LAST 24 HOURS
```

### Leggere il risultato

Confronta Ultimo con frequenza attesa e stato protocollo di acquisizione.

### Limiti e falsi positivi

Una sorgente completamente assente non produce righe; questa query da sola non trova tutti i silenzi.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S05

# Q015 / Finestra assoluta riproducibile

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Timestamp yyyy-MM-dd HH:mm:ss; documentare timezone console.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE sourceip = '<IP>'
ORDER BY starttime ASC
LIMIT 500
START '<START>' STOP '<STOP>'
```

### Leggere il risultato

Salva START/STOP, ora locale e conversione UTC nella timeline.

### Limiti e falsi positivi

Non combinare LAST e START/STOP; i parametri di tempo sono del motore, non del titolo Data.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S08

# Q016 / Anteprima del raw della sorgente

01 · Triage rapido / Rapida / Basso

### Prerequisiti

Permessi di lettura raw.

```
SELECT starttime, logsourceid, qid, username,
       UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_ID>
LIMIT 10 LAST 5 MINUTES
```

### Leggere il risultato

Usa questo campione per mappare campi custom e capire quale timestamp e IP sono raccolti.

### Limiti e falsi positivi

Il campione non è una baseline e può non includere il tipo di evento da cercare.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S03

# Q017 / Password spray per sorgente

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw. Hunt_TargetUser distingue il soggetto dal chiamante.

```
SELECT sourceip, UNIQUECOUNT("Hunt_TargetUser") AS Utenti,
       SUM(eventcount) AS Errori
FROM events
WHERE logsourceid = <LS_WIN>
  AND "Hunt_EventID" = '4625'
GROUP BY sourceip
HAVING Utenti >= 10 AND Errori >= 20
ORDER BY Errori DESC
LAST 15 MINUTES
```

## Leggere il risultato

Una sorgente su molti utenti è candidata spray. Verifica esiti, motivi di errore e IP zero/loopback.

## Limiti e falsi positivi

Soglie illustrative; gateway, RDS e scanner autorizzati possono concentrare utenti.

## Ridurre il lavoro di ricerca

Limita alle fonti Security/DC pertinenti e alla finestra utile. Filtra EventID prima dell'aggregazione; non aggiungere username singolo se vuoi misurare uno spray su molti utenti.

Riferimenti: S15, S05

# Q018 / Brute force su un account

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT "Hunt_TargetUser", sourceip,
       SUM(eventcount) AS Errori
FROM events
WHERE logsourceid = <LS_WIN>
  AND "Hunt_EventID" = '4625'
GROUP BY "Hunt_TargetUser", sourceip
HAVING Errori >= 15
ORDER BY Errori DESC
LAST 15 MINUTES
```

## Leggere il risultato

Cerca persistenza dei tentativi e logon riusciti nella stessa coppia user/IP con Q019.

## Limiti e falsi positivi

Password scadute o servizi con credenziali vecchie sono frequenti falsi positivi.

## Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S15

# Q019 / Successi ed errori dello stesso utente

02 · Identità e Active Directory / Intermedia / Medio

### Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw, "Hunt_TargetUser",
       "Hunt_LogonType"
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" IN ('4624','4625')
       AND "Hunt_TargetUser" ILIKE '<USER>')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Ordina la timeline e identifica il successo successivo agli errori sulla stessa risorsa e origine.

### Limiti e falsi positivi

La query restituisce eventi: non impone una sequenza né prova che la password sia stata indovinata.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S15, S09

# Q020 / Accessi RDP e credenziali esplicite

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw, "Hunt_TargetUser",
       "Hunt_LogonType"
FROM events
WHERE logsourceid = <LS_WIN>
  AND (("Hunt_EventID" = '4624' AND "Hunt_LogonType" = '10')
       OR "Hunt_EventID" = '4648')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Per 4648 esamina target server e processo; per RDP correla gateway e host finale.

## Limiti e falsi positivi

Un 4648 è tentativo con credenziali esplicite, non necessariamente un logon riuscito.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q021 / Nuovi account e riabilitazioni

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw, "Hunt_TargetUser"
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" IN ('4720','4722'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Separa l'account che esegue l'azione dall'account creato; verifica owner e ticket.

## Limiti e falsi positivi

Un indirizzo email nel payload non identifica da solo chi ha creato l'account.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q022 / Reset password e account modificati

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw, "Hunt_TargetUser"
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" IN ('4724','4738'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Controlla attore, soggetto, host amministrativo e modifiche effettive nel raw.

## Limiti e falsi positivi

Non tutti i 4738 modificano credenziali o privilegi.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q023 / Aggiunta a gruppi sensibili

02 · Identità e Active Directory / Intermedia / Medio

### Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" IN ('4728','4732','4756'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Priorità alle appartenenze privilegiate: usa SID e dominio, non il solo nome localizzato del gruppo.

### Limiti e falsi positivi

Gli eventi coprono gruppi globali/locali/universali: filtra poi i SID sensibili nel tuo ambiente.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q024 / Privilegi speciali su nuovi logon

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" = '4672')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Pivot su Logon ID e host verso 4624; controlla il contesto del token privilegiato.

## Limiti e falsi positivi

SYSTEM e servizi generano molti 4672; il privilegio non prova uso malevolo.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q025 / Ticket Kerberos: volume anomalo

02 · Identità e Active Directory / Avanzata / Medio

### Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw. Hunt_ServiceName dal ticket richiesto.

```
SELECT sourceip, "Hunt_TargetUser",
       UNIQUECOUNT("Hunt_ServiceName") AS Servizi,
       SUM(eventcount) AS Richieste
FROM events
WHERE logsourceid = <LS_WIN>
  AND "Hunt_EventID" = '4769'
GROUP BY sourceip, "Hunt_TargetUser"
HAVING Servizi >= 10
ORDER BY Richieste DESC
LAST 15 MINUTES
```

### Leggere il risultato

Candidato Kerberoasting: confronta servizi insoliti, account e tipo cifratura con baseline DC.

### Limiti e falsi positivi

RC4 o molti SPN non provano cracking; applicazioni legittime possono richiedere numerosi ticket.

### Ridurre il lavoro di ricerca

Per analisi ripetute estrai ServiceName e identità una volta nel parsing. Riduci la finestra, poi campiona il raw sui soli gruppi anomali; non rimuovere gli SPN dalla misura.

Riferimenti: S15

# Q026 / Preautenticazione Kerberos fallita

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" = '4771')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Esamina failure code e sorgente reale; distingui password errata da clock skew e problemi di trust.

## Limiti e falsi positivi

Non sostituire indiscriminatamente 4625 con 4771 nelle soglie.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q027 / Modifiche alle directory

02 · Identità e Active Directory / Intermedia / Medio

### Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" = '5136')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Cerca modifiche ad attributi sensibili quali SPN, deleghe e credenziali alternative; verifica valore e oggetto.

### Limiti e falsi positivi

Richiede audit Directory Service Changes e SACL pertinenti; assenza di hit può significare assenza di logging.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q028 / Operazioni directory da verificare

02 · Identità e Active Directory / Avanzata / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" = '4662')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Per ipotesi DCSync verifica diritti di replica nel raw e origine non DC, correlando account e host.

## Limiti e falsi positivi

4662 generico non è una firma DCSync; servono GUID, access mask e audit/SACL configurati.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q029 / Audit cancellato o policy cambiata

02 · Identità e Active Directory / Intermedia / Medio

## Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" IN ('1102','4719'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Conserva il raw e confronta l'ultimo evento prima del cambiamento con telemetria esterna all'host.

## Limiti e falsi positivi

Manutenzione può essere legittima; un attaccante può cancellare i log prima dell'inoltro.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q030 / Account di servizio usato da molte origini

02 · Identità e Active Directory / Avanzata / Medio

### Prerequisiti

Reference set ALN/ALNIC Hunt_ServiceUsers gestito; mapping DSM omogeneo.

```
SELECT username, UNIQUECOUNT(sourceip) AS Origini,
       SUM(eventcount) AS Eventi
FROM events
WHERE REFERENCESETCONTAINS('Hunt_ServiceUsers',username)
GROUP BY username
HAVING Origini >= 3
ORDER BY Origini DESC
LAST 60 MINUTES
```

### Leggere il risultato

Confronta con host autorizzati e tipo di logon. Un account tecnico su workstation inattesa è un pivot.

### Limiti e falsi positivi

Il set è stato corrente: non ricostruisce automaticamente appartenenze storiche.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S04

# Q031 / Autenticazioni IdP da IP e utenti

02 · Identità e Active Directory / Intermedia / Medio

### Prerequisiti

Audit WSO2/IdP con esito coerente, IP client affidabile e soggetto estratto.

```
SELECT sourceip, "Hunt_TargetUser", "Hunt_Result",
       SUM(eventcount) AS Totale
FROM events
WHERE logsourceid = <LS_IDP>
GROUP BY sourceip, "Hunt_TargetUser", "Hunt_Result"
ORDER BY Totale DESC
LIMIT 100 LAST 60 MINUTES
```

### Leggere il risultato

Distingui login, rinnovo token e chiamata API: sono operazioni diverse.

### Limiti e falsi positivi

Non fidarti di X-Forwarded-For arbitrario; accettalo soltanto da proxy attendibili.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q032 / Modifiche OAuth, consenso e credenziali

02 · Identità e Active Directory / Intermedia / Alto

### Prerequisiti

Audit Entra/IdP importati; richiede validazione locale dei nomi delle operazioni.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_CLOUD>
  AND (UTF8(payload) ILIKE '%credential%'
       OR UTF8(payload) ILIKE '%consent%'
       OR UTF8(payload) ILIKE '%service principal%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Esamina app ID, initiator, target e permessi concessi; pivot verso sign-in dell’app.

### Limiti e falsi positivi

Ricerca esplorativa nel raw; i vocaboli generici non costituiscono una regola pronta.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: S16, S09

# Q033 / Scansione verticale di porte

03 · Rete, DNS e flussi / Intermedia / Medio

### Prerequisiti

Flussi visibili sul percorso.

```
SELECT sourceip, destinationip,
       UNIQUECOUNT(destinationport) AS Porte,
       COUNT(*) AS Righe
FROM flows
WHERE sourceip = '<IP>'
GROUP BY sourceip, destinationip
HAVING Porte >= 20
ORDER BY Porte DESC
LAST 15 MINUTES
```

### Leggere il risultato

Molte porte sulla stessa destinazione suggeriscono scansione; controlla sensori e vulnerability scanner.

### Limiti e falsi positivi

I record non equivalgono a connessioni completate.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S07, S05

# Q034 / Scansione orizzontale di host

03 · Rete, DNS e flussi / Intermedia / Medio

### Prerequisiti

Flussi su segmento sufficientemente coperto.

```
SELECT sourceip, destinationport,
       UNIQUECOUNT(destinationip) AS Host
FROM flows
WHERE sourceip = '<IP>'
GROUP BY sourceip, destinationport
HAVING Host >= 30
ORDER BY Host DESC
LAST 15 MINUTES
```

### Leggere il risultato

Una porta su molti host è un candidato discovery; confronta attività scanner gestiti e scanner gestiti.

### Limiti e falsi positivi

Deployment software e monitoraggio possono avere lo stesso profilo.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S07, S05

# Q035 / Movimento laterale da un server

03 · Rete, DNS e flussi / Intermedia / Medio

## Prerequisiti

CIDR organizzativo; ripetere per le altre reti interne.

```
SELECT destinationip, destinationport,
       COUNT(*) AS Righe, SUM(sourcebytes) AS ByteOut
FROM flows
WHERE sourceip = '<HOST>'
  AND INCIDR('<INTERNAL_CIDR>',destinationip)
  AND destinationport IN (22,135,139,389,445,636,
                          3389,5985,5986)
GROUP BY destinationip, destinationport
ORDER BY Righe DESC
LAST 60 MINUTES
```

## Leggere il risultato

Confronta con matrice dei flussi: un nuovo target amministrativo dopo RCE ha priorità.

## Limiti e falsi positivi

LDAP/LDAPS da server applicativi può essere previsto.

## Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S07

# Q036 / LDAPS negato: il caso porta 636

03 · Rete, DNS e flussi / Rapida / Basso

### Prerequisiti

Firewall e asset role del client/server.

```
SELECT starttime, sourceip, destinationip,
       "Hunt_Action", QIDNAME(qid) AS Evento,
       UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_FW>
  AND sourceip = '<HOST>' AND destinationport = 636
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Verifica DNS, DC previsto, ACL, rinnovi e retry; correla i log del client per errori TLS o bind.

### Limiti e falsi positivi

Il firewall deny da solo non rivela credenziali né fallimento applicativo LDAP.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S09

# Q037 / Egress escluso dalle reti note

03 · Rete, DNS e flussi / Avanzata / Medio

### Prerequisiti

Hunt_InternalIPs di tipo IP, completo per gli indirizzi osservati.

```
SELECT sourceip, destinationip, destinationport,
       SUM(sourcebytes) AS ByteOut,
       SUM(destinationbytes) AS ByteIn
FROM flows
WHERE sourceip = '<HOST>'
  AND NOT REFERENCESETCONTAINS('Hunt_InternalIPs',
                               destinationip)
GROUP BY sourceip, destinationip, destinationport
ORDER BY ByteOut DESC
LIMIT 100 LAST 60 MINUTES
```

### Leggere il risultato

Usa una definizione interna che includa anche indirizzi pubblici posseduti dall’organizzazione.

### Limiti e falsi positivi

Non è sinonimo di Internet: set incompleto, NAT, IPv6 e cloud aziendale producono errori.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S04, S07

# Q038 / Trasferimenti prevalentemente in uscita

03 · Rete, DNS e flussi / Intermedia / Medio

### Prerequisiti

Orientamento dei flussi verificato su traffico noto.

```
SELECT sourceip, destinationip, destinationport,
       SUM(sourcebytes) AS OutB,
       SUM(destinationbytes) AS InB
FROM flows
WHERE sourceip = '<HOST>'
GROUP BY sourceip, destinationip, destinationport
HAVING OutB > 100000000 AND OutB > 10 * InB
ORDER BY OutB DESC
LAST 60 MINUTES
```

### Leggere il risultato

Candidato esfiltrazione da confrontare con backup, replica e upload autorizzati.

### Limiti e falsi positivi

Soglie esemplificative; non misurano dati sensibili e non superano il sampling.

### Ridurre il lavoro di ricerca

Se conosci l'host, mantieni il filtro sourceip. Somma i byte prima di chiedere raw/PCAP. Cambiare soglie o intervallo modifica ciò che viene segnalato.

Riferimenti: S07, S05

# Q039 / Volume piccolo e ripetuto: candidati C2

03 · Rete, DNS e flussi / Avanzata / Medio

### Prerequisiti

Record flows; STDEV supportato dalla build.

```
SELECT sourceip, destinationip, destinationport,
       COUNT(*) AS Righe, AVG(sourcebytes) AS MediaOut,
       STDEV(sourcebytes) AS Variabilita
FROM flows
WHERE sourceip = '<HOST>'
GROUP BY sourceip, destinationip, destinationport
HAVING Righe >= 20 AND MediaOut < 10000
ORDER BY Righe DESC
LAST 60 MINUTES
```

### Leggere il risultato

Seleziona coppie da analizzare nella timeline con Q040 e dati pacchetto.

### Limiti e falsi positivi

La varianza dei byte non è varianza degli intervalli; qui non si rileva periodicità.

### Ridurre il lavoro di ricerca

Usa l'host già individuato e 15-60 minuti. Non trasformare una riduzione di record in prova di beaconing: i timestamp delle sessioni servono ancora.

Riferimenti: S05, S07

# Q040 / Timeline per verificare un beacon

03 · Rete, DNS e flussi / Avanzata / Medio

### Prerequisiti

firstpackettime/lastpackettime presenti; export se campione sufficiente.

```
SELECT firstpackettime, lastpackettime,
       sourceip, destinationip, destinationport,
       sourcebytes, destinationbytes
FROM flows
WHERE sourceip = '<HOST>' AND destinationip = '<DST>'
ORDER BY firstpackettime ASC
LIMIT 1000 LAST 60 MINUTES
```

### Leggere il risultato

Calcola fuori da AQL gli intervalli tra inizio di sessioni deduplicate: mediana, dispersione e jitter.

### Limiti e falsi positivi

Active timeout del collector può creare falsa periodicità; LAG non va assunto disponibile in AQL.

### Ridurre il lavoro di ricerca

Esporta soltanto la coppia e i timestamp necessari; estendi il limite se troncava la serie. Confronta sessioni deduplicate, non singoli segmenti di flow.

Riferimenti: S07

# Q041 / DNS con molti nomi distinti

03 · Rete, DNS e flussi / Intermedia / Medio

### Prerequisiti

Query DNS dal client; proprietà estratta.

```
SELECT sourceip,
       UNIQUECOUNT("Hunt_DNSName") AS Nomi,
       SUM(eventcount) AS Richieste
FROM events
WHERE logsourceid = <LS_DNS>
GROUP BY sourceip
HAVING Nomi >= 100
ORDER BY Nomi DESC
LAST 15 MINUTES
```

### Leggere il risultato

Pivot sui nomi, tipo record, risposta e processi. Confronta browser, CDN e agenti di sicurezza.

### Limiti e falsi positivi

Alta cardinalità non è prova DGA o tunneling.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S05, S09

# Q042 / DNS NXDOMAIN per client

03 · Rete, DNS e flussi / Intermedia / Medio

### Prerequisiti

Rcode normalizzato a stringa NXDOMAIN, non valore numerico 3.

```
SELECT sourceip, SUM(eventcount) AS Errori,
       UNIQUECOUNT("Hunt_DNSName") AS Nomi
FROM events
WHERE logsourceid = <LS_DNS>
  AND "Hunt_DNSRcode" = 'NXDOMAIN'
GROUP BY sourceip
HAVING Errori >= 50
ORDER BY Errori DESC
LAST 15 MINUTES
```

### Leggere il risultato

Confronta con totale DNS dello stesso client; molti nomi errati possono guidare un’ipotesi DGA.

### Limiti e falsi positivi

Search suffix, typo e software configurato male sono frequenti.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q043 / DNS con etichette molto lunghe

03 · Rete, DNS e flussi / Avanzata / Alto

### Prerequisiti

DNSName string e regex verificata su esempi.

```
SELECT starttime, sourceip, "Hunt_DNSName",
       "Hunt_DNSType", UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_DNS>
  AND "Hunt_DNSName" MATCHES
      '(?i)[a-z0-9_-]{40,}[.].*'
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Campiona le etichette lunghe e associa dominio registrabile, frequenza e processo.

### Limiti e falsi positivi

Lunghezza non è entropia; vendor cloud e security usano token lunghi legittimi.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S06, S09

# Q044 / Connessioni a resolver non approvati

03 · Rete, DNS e flussi / Intermedia / Medio

### Prerequisiti

Set IP dei resolver ammessi; traffico TCP e UDP visibile.

```
SELECT sourceip, destinationip, destinationport,
       COUNT(*) AS Righe
FROM flows
WHERE sourceip = '<HOST>'
  AND destinationport IN (53,853)
  AND NOT REFERENCESETCONTAINS('Hunt_DNSResolvers',
                               destinationip)
GROUP BY sourceip, destinationip, destinationport
ORDER BY Righe DESC
LAST 60 MINUTES
```

### Leggere il risultato

Individua bypass DNS e DoT da verificare sul client.

### Limiti e falsi positivi

Non rileva tutto DoH su 443; le porte non identificano con certezza il protocollo.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S04, S07

# Q045 / SMB o amministrazione verso l’esterno

03 · Rete, DNS e flussi / Intermedia / Medio

## Prerequisiti

Perimetro definito con set completo e NAT noto.

```
SELECT sourceip, destinationip, destinationport,
       COUNT(*) AS Righe
FROM flows
WHERE sourceip = '<HOST>'
  AND destinationport IN (135,139,445,3389,5985,5986)
  AND NOT REFERENCESETCONTAINS('Hunt_InternalIPs',
                               destinationip)
GROUP BY sourceip, destinationip, destinationport
ORDER BY Righe DESC
LAST 60 MINUTES
```

## Leggere il risultato

Verifica eventuali autenticazioni esterne, client VPN e remote management autorizzato.

## Limiti e falsi positivi

SMB in uscita può esporre credenziali, ma questa query non dimostra cattura NTLM.

## Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S04, S07

# Q046 / IP prima e dopo NAT

03 · Rete, DNS e flussi / Avanzata / Medio

## Prerequisiti

Campi NAT IP/string e session ID estratti secondo vendor.

```
SELECT starttime, sourceip, destinationip,
       "Hunt_PreNATSrc", "Hunt_PostNATSrc",
       "Hunt_SessionID", UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_FW>
  AND (sourceip = '<IP>'
       OR "Hunt_PreNATSrc" = '<IP>'
       OR "Hunt_PostNATSrc" = '<IP>')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Riconcilia 5-tuple, tempo, interfaccia e direzione prima di attribuire un host.

## Limiti e falsi positivi

Un IP pubblico condiviso non identifica da solo un client.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S09

# Q047 / Traffico VPN/DTLS da verificare

03 · Rete, DNS e flussi / Intermedia / Medio

## Prerequisiti

Gateway esatto; porta locale eventualmente diversa; flow coverage.

```
SELECT sourceip, destinationip, protocolid,
       COUNT(*) AS Righe, SUM(sourcebytes) AS ByteIn
FROM flows
WHERE destinationip = '<GATEWAY>'
  AND destinationport = 443 AND protocolid IN (6,17)
GROUP BY sourceip, destinationip, protocolid
ORDER BY Righe DESC
LAST 60 MINUTES
```

## Leggere il risultato

Confronta TCP e UDP con log Gateway e anomalie di servizio nel periodo.

## Limiti e falsi positivi

Non è una firma NetScaler RCE: UDP/443 può essere DTLS o altro e il ruolo dei byte va verificato.

## Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S07, V05

# Q048 / BGP flap e reset di sessione

03 · Rete, DNS e flussi / Intermedia / Alto

## Prerequisiti

Syslog router con peer, reason e interfaccia.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_ROUTER>
  AND (UTF8(payload) ILIKE '%BGP%'
       AND (UTF8(payload) ILIKE '%reset%'
            OR UTF8(payload) ILIKE '%down%'
            OR UTF8(payload) ILIKE '%notification%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Confronta eventi del peer con link, manutenzione e volumi di rete.

## Limiti e falsi positivi

Flap BGP non prova DoS; QID e dizionario vendor possono richiedere adattamento.

## Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S01, S03

# Q049 / Shell generata da Office

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_ParentImage" ILIKE '%WINWORD.EXE'
       AND ("Hunt_Image" ILIKE '%cmd.exe'
            OR "Hunt_Image" ILIKE '%powershell.exe'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Pivot verso file, rete e mail iniziale; ripeti per EXCEL, OUTLOOK e OneNote.

### Limiti e falsi positivi

Macro approvate possono avviare shell; il solo parent non prova exploit.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q050 / Shell figlia di server Java

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_ParentImage" ILIKE '%java%'
       AND ("Hunt_Image" ILIKE '%cmd.exe'
            OR "Hunt_Image" ILIKE '%powershell.exe'
            OR "Hunt_Image" ILIKE '%/sh'
            OR "Hunt_Image" ILIKE '%/bash'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Collega a richiesta WAF, scrittura file e connessione egress: utile per WSO2 e applicazioni Java.

### Limiti e falsi positivi

Monitoring e job applicativi possono creare subprocessi legittimi.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q051 / PowerShell con argomenti codificati

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND (("Hunt_Image" ILIKE '%powershell.exe'
       OR "Hunt_Image" ILIKE '%pwsh.exe')
      AND ("Hunt_CommandLine" ILIKE '% -enc%'
           OR "Hunt_CommandLine" ILIKE '%FromBase64String%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Conserva la riga completa; decodifica offline e controlla 4104/AMSI se raccolti.

### Limiti e falsi positivi

Non rileva tutte le abbreviazioni e varianti; base64 è usata anche da amministratori.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q052 / LOLBins con destinazioni remote

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND (("Hunt_Image" ILIKE '%certutil.exe'
       OR "Hunt_Image" ILIKE '%bitsadmin.exe'
       OR "Hunt_Image" ILIKE '%mshta.exe'
       OR "Hunt_Image" ILIKE '%rundll32.exe')
      AND "Hunt_CommandLine" ILIKE '%http%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Esamina URL, firma binario, utente e parent; cerca file creati e rete.

### Limiti e falsi positivi

Uso duale e possibili URL nei parametri innocui; le varianti senza HTTP restano fuori.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q053 / msiexec e il falso positivo Citrix PVS

04 · Endpoint e applicazioni / Intermedia / Medio

## Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_Image" ILIKE '%PvsVmAgent.exe'
       OR ("Hunt_Image" ILIKE '%msiexec.exe'
           AND "Hunt_CommandLine" ILIKE '%http%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Per PvsVmAgent confronta percorso, firma, hash e installazione Citrix PVS prima di etichettare un attore.

## Limiti e falsi positivi

Un filename IOC è debole: nessuna attribuzione ad APT dal nome del file.

## Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q054 / Accesso a LSASS da processi insoliti

04 · Endpoint e applicazioni / Avanzata / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_TargetImage" ILIKE '%lsass.exe')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Usa eventi ProcessAccess con GrantedAccess/call trace e allowlist EDR per cercare accessi non previsti.

### Limiti e falsi positivi

Hunt_TargetImage va creato; antivirus e diagnostica accedono a LSASS. La query non prova dumping.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q055 / Nuovi servizi e scheduled task

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND ("Hunt_EventID" IN ('4697','4698','4702'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Esamina binario, task XML, account esecutore e firma. Correlare 7045 richiede la sorgente System separata.

### Limiti e falsi positivi

Questa query è Security: non include automaticamente eventi System con ID 7045.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S15, S09

# Q056 / Persistenza Unix nei log audit

04 · Endpoint e applicazioni / Intermedia / Alto

### Prerequisiti

auditd/EDR con comandi e file effettivamente registrati.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_LINUX>
  AND (UTF8(payload) ILIKE '%authorized_keys%'
       OR UTF8(payload) ILIKE '%/etc/cron%'
       OR UTF8(payload) ILIKE '%systemctl enable%'
       OR UTF8(payload) ILIKE '%useradd%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Valida host, auid, euid, processo padre e change management.

### Limiti e falsi positivi

Stringhe raw esplorative: scritture via syscall senza pathname o execve spezzato possono sfuggire.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S01, S03

# Q057 / Download seguito da shell

04 · Endpoint e applicazioni / Intermedia / Alto

### Prerequisiti

Command line completa o audit exec con pipeline ricostruita.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_LINUX>
  AND ((UTF8(payload) ILIKE '%curl%'
        OR UTF8(payload) ILIKE '%wget%')
       AND (UTF8(payload) ILIKE '%| sh%'
            OR UTF8(payload) ILIKE '%| bash%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Cerca URL, file temporanei e rete associata al processo.

### Limiti e falsi positivi

L’audit può registrare la pipeline in eventi diversi; la coesistenza testuale non è garantita.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: S01, S03

# Q058 / Tunnel e inoltri remoti

04 · Endpoint e applicazioni / Intermedia / Alto

### Prerequisiti

Process audit e parent/user.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_LINUX>
  AND (UTF8(payload) ILIKE '%ssh -R%'
       OR UTF8(payload) ILIKE '%ssh -L%'
       OR UTF8(payload) ILIKE '%socat%'
       OR UTF8(payload) ILIKE '%chisel%'
       OR UTF8(payload) ILIKE '%cloudflared%tunnel%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Confronta binario, avvio e connessione persistente con tool di supporto approvati.

### Limiti e falsi positivi

Non è una firma di tutte le opzioni SSH; ordine argomenti e tool rinominati sfuggono.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S01, S03

# Q059 / Nuovo JSP scritto nel webroot

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

EDR/FileCreate; Hunt_TargetFilename string completa.

```
SELECT starttime, sourceip, "Hunt_Image",
       "Hunt_TargetFilename", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND "Hunt_TargetFilename" ILIKE '%webapps%'
  AND "Hunt_TargetFilename" ILIKE '%.jsp'
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Abbina writer, hash, richiesta in access log e avvio subprocesso; priorità se fuori da deployment.

### Limiti e falsi positivi

Il filtro cerca una famiglia di path, non tutte le webshell; deploy Java legittimi creano JSP.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17

# Q060 / Richieste verso file server-side sospetti

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

HTTP access log con path e status.

```
SELECT sourceip, "Hunt_URI", "Hunt_Status",
       SUM(eventcount) AS Richieste
FROM events
WHERE logsourceid = <LS_WEB>
  AND ("Hunt_URI" ILIKE '%.jsp%'
       OR "Hunt_URI" ILIKE '%.aspx%')
GROUP BY sourceip, "Hunt_URI", "Hunt_Status"
ORDER BY Richieste DESC
LIMIT 100 LAST 60 MINUTES
```

### Leggere il risultato

Verifica se il file era atteso, quando è comparso e quale processo l'ha scritto.

### Limiti e falsi positivi

Estensioni molto comuni: restringi host, percorso e periodo di incidente.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q061 / Errori HTTP per endpoint

04 · Endpoint e applicazioni / Intermedia / Medio

### Prerequisiti

Status string, URI senza segreti se possibile.

```
SELECT "Hunt_URI", "Hunt_Status",
       SUM(eventcount) AS Totale
FROM events
WHERE logsourceid = <LS_WEB>
  AND "Hunt_Status" IN ('400','401','403','500','502','503')
GROUP BY "Hunt_URI", "Hunt_Status"
ORDER BY Totale DESC
LIMIT 50 LAST 15 MINUTES
```

### Leggere il risultato

Cerca burst di parsing error e 5xx prima delle azioni successive.

### Limiti e falsi positivi

Un exploit riuscito può rispondere 200 o non generare access log.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q062 / Traversal in URI, anche codificato

04 · Endpoint e applicazioni / Avanzata / Alto

### Prerequisiti

URI raw originale oltre all'eventuale URI normalizzata.

```
SELECT starttime, sourceip, "Hunt_URI",
       "Hunt_Status", UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WEB>
  AND "Hunt_URI" MATCHES
      '(?i).*([.][.]/|[.][.]%2f|%252e%252e).*'
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Confronta URI vista da WAF e backend con request ID; campioni diversi possono indicare decodifiche differenti.

### Limiti e falsi positivi

Copertura parziale di encoding e separatori; presenza di traversal non prova accesso al file.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S09

# Q063 / Attività Kubernetes amministrativa

04 · Endpoint e applicazioni / Avanzata / Medio

### Prerequisiti

Audit Kubernetes importato; stage, user, sourceIPs e responseStatus conservati.

```
SELECT starttime, username, "Hunt_K8sVerb",
       "Hunt_K8sResource", "Hunt_K8sSubresource",
       "Hunt_K8sObject", UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_K8S>
  AND ("Hunt_K8sSubresource" IN ('exec','attach')
       OR "Hunt_K8sResource" = 'secrets')
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Correla subject, verb, namespace, request URI e autorizzazione con pipeline CI/CD e change.

### Limiti e falsi positivi

Richieste denied e risposta successful hanno significati diversi; non è una firma container escape.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S09

# Q064 / Rimozione log e disattivazione controlli

04 · Endpoint e applicazioni / Intermedia / Alto

### Prerequisiti

Process/script telemetry EDR presente; adattare al formato locale.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_EDR>
  AND (UTF8(payload) ILIKE '%wevtutil%cl %'
       OR UTF8(payload) ILIKE '%Clear-EventLog%'
       OR UTF8(payload) ILIKE '%Set-MpPreference%'
       OR UTF8(payload) ILIKE '%auditctl -e 0%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Verifica il comando effettivo e l'esito; cerca gaps di acquisizione nel periodo successivo.

### Limiti e falsi positivi

La stringa può essere in uno script di amministrazione o in un rilevamento senza esecuzione.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: S01, S03

# Q065 / Numero di righe contro numero di eventi

05 · AQL avanzato e qualità / Avanzata / Basso

### Prerequisiti

Coalescenza e politica di acquisizione conosciute.

```
SELECT logsourceid, COUNT(*) AS Righe,
       SUM(eventcount) AS Eventi,
       MAX(eventcount) AS MaxCoalescenza
FROM events
WHERE logsourceid = <LS_ID>
GROUP BY logsourceid
LAST 60 MINUTES
```

### Leggere il risultato

Se Eventi supera Righe, le soglie sui COUNT(*) misurano record memorizzati, non ogni evento originale.

### Limiti e falsi positivi

L’aggregazione può conservare un solo raw rappresentativo: non ricostruire dettagli mai archiviati.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S14, S05

# Q066 / Volume per bucket di cinque minuti

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

starttime in millisecondi; LONG conversione intera.

```
SELECT LONG(starttime / 300000) * 300000 AS BucketMs,
       SUM(eventcount) AS Eventi
FROM events
WHERE logsourceid = <LS_ID>
GROUP BY BucketMs
ORDER BY BucketMs ASC
LAST 60 MINUTES
```

### Leggere il risultato

Esporta BucketMs come epoch: usa bucket allineati per confrontare sorgenti.

### Limiti e falsi positivi

I bucket senza dati non appaiono; la coalescenza può spostare volumi tra intervalli.

### Ridurre il lavoro di ricerca

Mantieni il confronto temporale nativo nel motore; formatta il bucket solo nell'output. Ridurre da 5 a 1 minuto aumenta il numero di gruppi e cambia la risoluzione.

Riferimenti: S03, S05

# Q067 / Ritardo tra device e storage

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

devicetime e storageTime significativi nel DSM.

```
SELECT logsourceid,
       AVG((storageTime-devicetime)/1000.0) AS MediaSec,
       MAX((storageTime-devicetime)/1000.0) AS MaxSec
FROM events
WHERE logsourceid = <LS_ID> AND devicetime > 0
GROUP BY logsourceid
LAST 60 MINUTES
```

### Leggere il risultato

Delta include trasporto, buffering e clock: esamina anche valori negativi e deviazioni NTP.

### Limiti e falsi positivi

Non è una misura pura della latenza di rete; timezone o parsing errati falsano il delta.

### Ridurre il lavoro di ricerca

Interroga una sorgente alla volta quando cerchi il ritardo di quella sorgente; estrai pochi raw solo dopo l'aggregazione e verifica i clock.

Riferimenti: S07, S03

# Q068 / IP in reference set di hunting

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Reference set IP popolato, TTL e provenance documentati.

```
SELECT starttime, sourceip, destinationip,
       QIDNAME(qid) AS Evento
FROM events
WHERE REFERENCESETCONTAINS('Hunt_IOC_IP',sourceip)
   OR REFERENCESETCONTAINS('Hunt_IOC_IP',destinationip)
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Un match priorizza il triage; verifica validità temporale, shared hosting e ruolo dell’indicatore.

### Limiti e falsi positivi

Membership consultata è quella disponibile durante la ricerca, non necessariamente al tempo dell’evento.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S04

# Q069 / Enrichment dell’asset da mappa

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Reference map Hunt_AssetOwner: chiave IP resa nella forma supportata e valore string owner.

```
SELECT sourceip,
       REFERENCEMAP('Hunt_AssetOwner',sourceip) AS Owner,
       SUM(eventcount) AS Totale
FROM events
WHERE sourceip = '<HOST>'
GROUP BY sourceip
LAST 60 MINUTES
```

### Leggere il risultato

Unisci responsabilità di remediation al pivot tecnico senza modificare gli eventi originali.

### Limiti e falsi positivi

NULL può essere assenza di chiave, dominio errato o dato mancante; non significa host non posseduto.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S04, S18

# Q070 / Tabella utenti: ruolo e reparto

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Reference table Hunt_UserMeta con colonne Role e Department.

```
SELECT username,
       REFERENCETABLE('Hunt_UserMeta','Role',username)
         AS Ruolo,
       REFERENCETABLE('Hunt_UserMeta','Department',username)
         AS Reparto,
       SUM(eventcount) AS Totale
FROM events
WHERE username IS NOT NULL
GROUP BY username
LIMIT 100 LAST 60 MINUTES
```

### Leggere il risultato

Usa il contesto per distinguere accessi previsti da incongruenze; controlla formato e case dell’identità.

### Limiti e falsi positivi

Enrichment corrente: una promozione o trasferimento successivi non spiegano automaticamente eventi storici.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S18

# Q071 / Host non autorizzati per account di servizio

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Map of sets: chiave username, valori IP; set ServiceUsers. Testare semantica domain della build.

```
SELECT starttime, username, sourceip,
       QIDNAME(qid) AS Evento
FROM events
WHERE logsourceid = <LS_WIN>
  AND "Hunt_EventID" = '4624'
  AND REFERENCESETCONTAINS('Hunt_ServiceUsers',username)
  AND NOT REFERENCEMAPSETCONTAINS(
      'Hunt_UserAllowedIPs',username,sourceip)
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Misura una relazione user-host: più utile di una allowlist globale degli IP.

### Limiti e falsi positivi

Chiave mancante può segnalare baseline incompleta. Conferma che username sia il soggetto del logon.

### Ridurre il lavoro di ricerca

Metti la relazione user-IP dopo un perimetro selettivo di eventi. La mappa deve essere completa; un set troppo ampio non è una scorciatoia equivalente.

Riferimenti: S04, S13

# Q072 / Successi per utenti con fallimenti recenti

05 · AQL avanzato e qualità / Avanzata / Alto

### Prerequisiti

Windows Security raccolto e Hunt_EventID string estratto dall'EventID XML, non da un numero casuale nel raw. Sottoquery IN disponibile.

```
SELECT starttime, sourceip, "Hunt_TargetUser",
       UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WIN>
  AND "Hunt_EventID" = '4624'
  AND "Hunt_TargetUser" IN (
    SELECT "Hunt_TargetUser" FROM events
    WHERE logsourceid = <LS_WIN>
      AND "Hunt_EventID" = '4625'
    GROUP BY "Hunt_TargetUser"
    LIMIT 10000 LAST 15 MINUTES)
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Riduce il set di candidati da correlare poi per host, IP e ordine temporale.

### Limiti e falsi positivi

IN confronta utenti soltanto: non impone prima errore poi successo. La sottoquery ha un massimo documentato di 10.000 risultati.

### Ridurre il lavoro di ricerca

Valuta separatamente la subquery: sorgente, EventID, finestra e cardinalità utenti. Un LIMIT interno più basso può togliere candidati; preferisci suddividere un set completo e disgiunto.

Riferimenti: S11

# Q073 / Sorgenti rare nella finestra

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Raccolta continua per la finestra.

```
SELECT sourceip, destinationip,
       SUM(eventcount) AS Totale
FROM events
WHERE logsourceid = <LS_WEB>
GROUP BY sourceip, destinationip
HAVING Totale <= 3
ORDER BY Totale ASC
LIMIT 100 LAST 24 HOURS
```

### Leggere il risultato

Cerca coppie poco frequenti da arricchire con asset e richieste.

### Limiti e falsi positivi

Raro nelle ultime 24 ore non equivale a first seen: manca confronto con storico precedente.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S05

# Q074 / Nuove destinazioni rispetto alla baseline

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Set IP baseline costruito su storico precedente alla finestra corrente e congelato per il test.

```
SELECT destinationip, destinationport,
       COUNT(*) AS Righe
FROM flows
WHERE sourceip = '<HOST>'
  AND NOT REFERENCESETCONTAINS('Hunt_BaselineDestIP',
                               destinationip)
GROUP BY destinationip, destinationport
ORDER BY Righe DESC
LAST 60 MINUTES
```

### Leggere il risultato

Esporta 14-30 giorni puliti, revisiona destinazioni e poi valuta quelle nuove.

### Limiti e falsi positivi

Se aggiorni il set con l’ora corrente prima della query nascondi i nuovi contatti; versionare la baseline.

### Ridurre il lavoro di ricerca

Conserva il filtro dell’host e lo snapshot baseline precedente. Non velocizzare aggiornando il set con i contatti della finestra corrente: li nasconderesti.

Riferimenti: S04, S07

# Q075 / Rapporto allow/deny con CASE

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Hunt_Action string canonica. CASE supportato; verificare UI report/Pulse separatamente.

```
SELECT sourceip,
       SUM(CASE WHEN "Hunt_Action" = 'deny'
                THEN eventcount ELSE 0 END) AS Deny,
       SUM(CASE WHEN "Hunt_Action" = 'allow'
                THEN eventcount ELSE 0 END) AS AllowN
FROM events
WHERE logsourceid = <LS_FW>
GROUP BY sourceip
ORDER BY Deny DESC
LIMIT 50 LAST 60 MINUTES
```

### Leggere il risultato

Leggi entrambi i numeri: un alto deny non esclude sessioni consentite utili all’attaccante.

### Limiti e falsi positivi

Altri esiti non entrano nei due conteggi; non usarli come denominatore di tutte le sessioni.

### Ridurre il lavoro di ricerca

Filtra sorgente e finestra prima dei contatori. Rimuovi l’ordinamento solo se basta una tabella non classificata; gli esiti diversi da allow/deny restano fuori.

Riferimenti: S19

# Q076 / Sottoquery FROM su candidati aggregati

05 · AQL avanzato e qualità / Avanzata / Alto

### Prerequisiti

Supporto subquery FROM nella build.

```
SELECT sourceip, N
FROM (
  SELECT sourceip, UNIQUECOUNT(destinationip) AS N
  FROM events
  WHERE logsourceid = <LS_FW>
  GROUP BY sourceip
  LAST 15 MINUTES)
WHERE N >= 30
ORDER BY N DESC
```

### Leggere il risultato

È un esempio di filtro sul cursore aggregato; per casi semplici HAVING è più leggibile.

### Limiti e falsi positivi

Non è una JOIN tra events e flows; evita di trattare Ariel come SQL completo.

### Ridurre il lavoro di ricerca

Per questo caso usa HAVING sul gruppo e togli il livello esterno se il risultato è equivalente. La sottoquery FROM non rende automaticamente la ricerca più rapida.

Riferimenti: S11

# Q077 / Accesso a dati accumulati GLOBALVIEW

05 · AQL avanzato e qualità / Avanzata / Basso

### Prerequisiti

Saved search accumulata e schema reale. Accesso GLOBALVIEW tramite API documentata; validare il contesto Pulse separatamente.

```
SELECT *
FROM GLOBALVIEW('<SAVED_SEARCH>','NORMAL')
LIMIT 20 LAST 24 HOURS
```

### Leggere il risultato

Prima osserva nomi colonne e timestamp; costruisci poi aggregazioni sullo schema restituito.

### Limiti e falsi positivi

Non sostituisce il raw e non ricostruisce dati mai accumulati.
NORMAL/HOURLY/DAILY dipendono dalla vista.

### Ridurre il lavoro di ricerca

Verifica nome/schema della vista e usa il percorso API documentato. Seleziona le sole colonne necessarie; una vista senza raw non sostituisce l’indagine di dettaglio.

Riferimenti: S20

# Q078 / Identificare QID con parsing insufficiente

05 · AQL avanzato e qualità / Avanzata / Basso

### Prerequisiti

Sorgente per cui username o IP dovrebbero essere presenti.

```
SELECT qid, QIDNAME(qid) AS Evento,
       SUM(eventcount) AS Totale
FROM events
WHERE logsourceid = <LS_ID>
  AND (username IS NULL OR sourceip = '0.0.0.0')
GROUP BY qid
ORDER BY Totale DESC
LIMIT 30 LAST 60 MINUTES
```

### Leggere il risultato

Campiona il raw, verifica DSM e proprietà; confronta prima/dopo un cambio formato del vendor.

### Limiti e falsi positivi

Non tutti gli eventi hanno un utente o un IP: è indicatore di qualità contestuale, non errore certo.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q079 / Copertura di una proprietà custom

05 · AQL avanzato e qualità / Avanzata / Medio

### Prerequisiti

Hunt_URI esistente ed eventi HTTP attesi.

```
SELECT COUNT(*) AS Totale,
       SUM(CASE WHEN "Hunt_URI" IS NOT NULL
                THEN 1 ELSE 0 END) AS ConURI
FROM events
WHERE logsourceid = <LS_WEB>
LAST 60 MINUTES
```

### Leggere il risultato

Confronta percentuale per QID e per versione log; un calo può spiegare query apparentemente vuote.

### Limiti e falsi positivi

Conta righe, non singole richieste originarie; stringhe vuote possono non essere NULL.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S09, S19

# Q080 / Distribuzione dei dati tra domini

05 · AQL avanzato e qualità / Avanzata / Basso

### Prerequisiti

Accesso autorizzato ai domini pertinenti.

```
SELECT domainid, logsourceid,
       SUM(eventcount) AS Totale
FROM events
WHERE sourceip = '<IP>'
GROUP BY domainid, logsourceid
ORDER BY Totale DESC
LAST 60 MINUTES
```

### Leggere il risultato

Verifica che l’IP sia nel tenant corretto e che i reference data abbiano lo stesso ambito.

### Limiti e falsi positivi

Nessuna query aggira i permessi: un dominio non visibile non compare.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S07, S04

# Q081 / Pivot su un IP indicatore parametrico

06 · Casi ed exploit / Rapida / Basso

### Prerequisiti

Indicatore IP fornito dall’analista; finestra e fonte documentate.

```
SELECT starttime, logsourceid, sourceip, destinationip,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE sourceip = '<IOC_IP>'
   OR destinationip = '<IOC_IP>'
ORDER BY starttime ASC
LIMIT 500 LAST 24 HOURS
```

### Leggere il risultato

Correla accessi web, IdP, endpoint e rete prima di formulare un’ipotesi sul vettore.

### Limiti e falsi positivi

È un esempio parametrico, non un IOC verificato né un’attribuzione pubblica.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01, S01

# Q082 / WSO2: accessi a /fileupload

06 · Casi ed exploit / Intermedia / Medio

### Prerequisiti

WAF/access log dell’istanza WSO2; vhost reale e routing backend.

```
SELECT starttime, sourceip, "Hunt_HTTPHost",
       "Hunt_Method", "Hunt_URI", "Hunt_Status"
FROM events
WHERE logsourceid = <LS_WEB>
  AND "Hunt_HTTPHost" ILIKE '<VHOST>'
  AND "Hunt_URI" ILIKE '%/fileupload%'
ORDER BY starttime ASC
LIMIT 200 LAST 24 HOURS
```

### Leggere il risultato

Per CVE-2022-29464 correla upload, scrittura nel webroot, richiesta al nuovo file e processo figlio.

### Limiti e falsi positivi

Endpoint visitato non prova upload o RCE. Identity Server 5.8.0 è nell’elenco vendor, ma patch/update level vanno verificati.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: V01, V02

# Q083 / WSO2: tracce upload e deployment

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Audit e log Carbon/WSO2 con dettagli di upload/deployment.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_IDP>
  AND (UTF8(payload) ILIKE '%fileupload%'
       OR UTF8(payload) ILIKE '%repository/deployment%'
       OR UTF8(payload) ILIKE '%webapps%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Allinea con Q050 e Q059; conserva file e timestamp del server se acquisiti con procedure forensi.

### Limiti e falsi positivi

Il corpo multipart e Content-Disposition spesso non sono nei log: richiedere PCAP/NDR o evidenza host.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: V01, V02

# Q084 / IdP: chiamate SCIM e provisioning

06 · Casi ed exploit / Avanzata / Medio

### Prerequisiti

Access log vhost IdP; audit provisioning e token associabili.

```
SELECT starttime, sourceip, "Hunt_Method",
       "Hunt_URI", "Hunt_Status", username
FROM events
WHERE logsourceid = <LS_WEB>
  AND "Hunt_HTTPHost" ILIKE '<VHOST>'
  AND ("Hunt_URI" ILIKE '%/scim2/%'
       OR "Hunt_URI" ILIKE '%/services/%')
ORDER BY starttime ASC
LIMIT 200 LAST 24 HOURS
```

### Leggere il risultato

Confronta azione HTTP e creazione/modifica utente nell’audit. Rileva anche abuso di credenziali valide.

### Limiti e falsi positivi

Percorso istituzionale può essere legittimo. CVE-2019 documentata come corretta in 5.8.0 non va attribuita automaticamente a quella versione.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: V03, G01

# Q085 / Pattern di comandi negli header SMTP

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Header SMTP completo realmente inoltrato dalla sorgente.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_MAIL>
  AND (UTF8(payload) ILIKE '%Message-ID:%'
       AND (UTF8(payload) ILIKE '%TO PROGRAM%'
            OR UTF8(payload) ILIKE '%<EXEC_MARKER>%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

La co-occorrenza guida il triage; cerca conferme di processo, file e rete.

### Limiti e falsi positivi

La presenza nel log non dimostra esecuzione e non assegna una CVE a un gateway.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01, S03

# Q086 / Marker generici di comando e staging mail

06 · Casi ed exploit / Avanzata / Alto

## Prerequisiti

Marker di comando/staging definiti dall’analista; telemetria che li registri.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_MAIL>
  AND (UTF8(payload) ILIKE '%<EXEC_MARKER>%'
       OR UTF8(payload) ILIKE '%<STAGE_PATH>%'
       OR UTF8(payload) ILIKE '%COPY%TO PROGRAM%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

## Leggere il risultato

Correla i marker con evidenze indipendenti di processi, file e connessioni.

## Limiti e falsi positivi

Pattern didattici configurabili, non indicatori convalidati di una campagna.

## Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01, S03

# Q087 / Contatti gateway mail verso un IOC fornito

06 · Casi ed exploit / Intermedia / Basso

### Prerequisiti

Identità e NAT del gateway verificati; destinazione fornita dall’analista.

```
SELECT firstpackettime, sourceip, destinationip,
       destinationport, sourcebytes, destinationbytes
FROM flows
WHERE sourceip = '<ESA_IP>'
  AND destinationip = '<IOC_IP>'
ORDER BY firstpackettime ASC
LIMIT 500 LAST 24 HOURS
```

### Leggere il risultato

Distingui handshake, richiesta, trasferimento ed esecuzione tramite log indipendenti.

### Limiti e falsi positivi

I byte non identificano uno script né ne dimostrano l’esecuzione.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01, S07

# Q088 / ESA: management e quarantine esposti

06 · Casi ed exploit / Avanzata / Medio

### Prerequisiti

Porte da sostituire con listener reali; NAT e policy note.

```
SELECT sourceip, destinationport,
       COUNT(*) AS Righe, SUM(sourcebytes) AS ByteIn
FROM flows
WHERE destinationip = '<ESA_IP>'
  AND destinationport IN (80,443,6025,6080,6443,8443)
GROUP BY sourceip, destinationport
ORDER BY Righe DESC
LAST 24 HOURS
```

### Leggere il risultato

Per CVE-2025-20393 verifica release AsyncOS e Spam Quarantine raggiungibile; cercare log HTTP e supporto TAC.

### Limiti e falsi positivi

La lista è esplorativa, non porte universali ESA. L’advisory descrive richieste HTTP: non lo identifica automaticamente con il caso Message-ID.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: V04

# Q089 / Exchange: superfici web e PowerShell

06 · Casi ed exploit / Intermedia / Medio

### Prerequisiti

IIS/HttpProxy access logs; mappare campi secondo log reale.

```
SELECT starttime, sourceip, "Hunt_URI",
       "Hunt_Method", "Hunt_Status", username
FROM events
WHERE logsourceid = <LS_EXCH>
  AND ("Hunt_URI" ILIKE '%/autodiscover/%'
       OR "Hunt_URI" ILIKE '%/powershell%'
       OR "Hunt_URI" ILIKE '%/ecp/%')
ORDER BY starttime ASC
LIMIT 300 LAST 60 MINUTES
```

### Leggere il risultato

Usa come inventario di superficie; cerca sequenze anomale seguite da shell, file o modifiche.

### Limiti e falsi positivi

Path comuni di Exchange: non sono firme sufficienti di ProxyShell, ProxyLogon o exploit nuovo.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S09

# Q090 / Exchange: worker web che genera shell

06 · Casi ed exploit / Avanzata / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_ParentImage" ILIKE '%w3wp.exe'
       AND ("Hunt_Image" ILIKE '%cmd.exe'
            OR "Hunt_Image" ILIKE '%powershell.exe'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Associa worker/app pool, request ID e file creati; amplia con EDR process tree.

### Limiti e falsi positivi

Alcuni componenti amministrativi possono avviare PowerShell: serve contesto del pool e baseline.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: S17, S09

# Q091 / Exchange ibrido: principal e certificati

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Audit Entra importato; operazioni, target e initiator conservati.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_CLOUD>
  AND (UTF8(payload) ILIKE '%00000002-0000-0ff1-ce00-000000000000%'
       OR UTF8(payload) ILIKE '%keyCredentials%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Per CVE-2025-53786 controlla configurazione hybrid, dedicated app e modifiche credenziali del principal.

### Limiti e falsi positivi

Questo non è uno zero-click Exchange: richiede il contesto di privilegi amministrativi on-prem indicato nelle fonti. Stringhe non bastano a provare abuso.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: V06, S16

# Q092 / Outlook: figli di processo da investigare

06 · Casi ed exploit / Avanzata / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_ParentImage" ILIKE '%OUTLOOK.EXE'
       AND ("Hunt_Image" ILIKE '%cmd.exe'
            OR "Hunt_Image" ILIKE '%powershell.exe'
            OR "Hunt_Image" ILIKE '%mshta.exe'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Correla mail, allegato, patch level, crash/WER e rete; query comportamentale per il caso Outlook.

### Limiti e falsi positivi

Non è una firma della CVE-2026-78509. La ricerca ha individuato un record NVD riferito a Outlook, ma la pagina MSRC richiede JS: dettagli vendor non verificati qui.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: V14, V15, S17

# Q093 / Allegati OneNote e dominio parametrico

06 · Casi ed exploit / Intermedia / Alto

### Prerequisiti

Mail log con nomi allegati/URL e telemetria endpoint.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_MAIL>
  AND (UTF8(payload) ILIKE '%.one%'
       OR UTF8(payload) ILIKE '%.onetoc2%'
       OR UTF8(payload) ILIKE '%<MAIL_DOMAIN>%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Parti da allegati e dominio fornito per pivot su hash e processo.

### Limiti e falsi positivi

L’estensione non è prova di malware. Il dominio è un parametro da validare indipendentemente.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01, S03

# Q094 / Pivot su User-Agent HTTP fornito

06 · Casi ed exploit / Rapida / Basso

### Prerequisiti

User-Agent osservato in access log attendibili.

```
SELECT starttime, sourceip, "Hunt_HTTPHost",
       "Hunt_URI", "Hunt_Method", "Hunt_Status"
FROM events
WHERE logsourceid = <LS_WEB>
  AND "Hunt_UserAgent" ILIKE '%<USER_AGENT>%'
ORDER BY starttime ASC
LIMIT 300 LAST 24 HOURS
```

### Leggere il risultato

Verifica ritmo, percorsi, esiti, autorizzazione e attività successive.

### Limiti e falsi positivi

User-Agent falsificabile: non basta per attribuire un attore o un exploit.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01

# Q095 / Pivot DNS su domini forniti

06 · Casi ed exploit / Intermedia / Basso

### Prerequisiti

DNS con client attribuibile e indicatori con provenienza nota.

```
SELECT starttime, sourceip, "Hunt_DNSName",
       "Hunt_DNSRcode", UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_DNS>
  AND ("Hunt_DNSName" ILIKE '<DOMAIN_A>'
       OR "Hunt_DNSName" ILIKE '<DOMAIN_B>')
ORDER BY starttime ASC
LIMIT 300 LAST 24 HOURS
```

### Leggere il risultato

Verifica fonte TI, validità dell’indicatore, contesto della pagina e redirect.

### Limiti e falsi positivi

Una classificazione TI o un dominio di tracking non prova da solo C2 o attribuzione APT.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01

# Q096 / Endpoint RPC blockchain condivisi

06 · Casi ed exploit / Intermedia / Medio

### Prerequisiti

Proxy/Host/SNI mappati con semantica esplicita.

```
SELECT starttime, sourceip, "Hunt_HTTPHost",
       "Hunt_URI", "Hunt_UserAgent"
FROM events
WHERE logsourceid = <LS_PROXY>
  AND ("Hunt_HTTPHost" ILIKE '<RPC_DOMAIN_A>'
       OR "Hunt_HTTPHost" ILIKE '<RPC_DOMAIN_B>')
ORDER BY starttime ASC
LIMIT 300 LAST 24 HOURS
```

### Leggere il risultato

Associa processo chiamante, applicazione e contenuto RPC se acquisito.

### Limiti e falsi positivi

Infrastrutture condivise possono avere usi legittimi: nessuna attribuzione malware o furto dal solo dominio.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01

# Q097 / NetScaler: crash e modifiche sospette

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Syslog/support telemetry NetScaler; release/build e configurazione DTLS note.

```
SELECT starttime, sourceip, QIDNAME(qid) AS Evento,
       UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_NETSCALER>
  AND (UTF8(payload) ILIKE '%crash%'
       OR UTF8(payload) ILIKE '%core dump%'
       OR UTF8(payload) ILIKE '%configuration%changed%')
ORDER BY starttime ASC
LIMIT 300 LAST 24 HOURS
```

### Leggere il risultato

Priorità alle CVE-2026-88771/88772 verificate nel bulletin vendor; unisci Q047, Q074 e analisi appliance.

### Limiti e falsi positivi

Hunting comportamentale, non firma exploit. Assenza di crash non esclude RCE.

### Ridurre il lavoro di ricerca

Parti da asset/versione interessata e periodo del sintomo; campiona i raw. Il solo incremento di crash non dimostra sfruttamento o bonifica.

Riferimenti: V05

# Q098 / WSO2 2026: esiti JWT e autenticazione

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Log API Manager/JWT con esiti e algoritmo; confermare prodotto realmente in uso.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_IDP>
  AND (UTF8(payload) ILIKE '%JWT%'
       AND (UTF8(payload) ILIKE '%algorithm%'
            OR UTF8(payload) ILIKE '%signature%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

CVE-2026-5430 riguarda specifiche versioni API Manager e prodotti elencati, con bypass JWT. Cercare accessi anomali anche senza errori.

### Limiti e falsi positivi

Non estendere l’applicabilità a Identity Server 5.8.0. Gli errori non identificano lo sfruttamento riuscito.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: V07

# Q099 / WSO2 2026: problemi del throttling

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Log API Gateway/Traffic Manager e metriche disponibilità importate.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_IDP>
  AND (UTF8(payload) ILIKE '%throttl%'
       AND (UTF8(payload) ILIKE '%error%'
            OR UTF8(payload) ILIKE '%exception%'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Per CVE-2026-4249 verifica prodotto e update level; correla errori, richieste e persistente indisponibilità.

### Limiti e falsi positivi

È DoS applicativo nel contesto vendor, non prova RCE; un semplice errore di throttling non basta.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: V08

# Q100 / Email gateway: anomalie oltre le firme

06 · Casi ed exploit / Avanzata / Alto

### Prerequisiti

Gateway, AV/DLP e parser che espongono errori in syslog; non tutti lo fanno.

```
SELECT qid, QIDNAME(qid) AS Evento,
       SUM(eventcount) AS Totale,
       MIN(starttime) AS Primo, MAX(starttime) AS Ultimo
FROM events
WHERE logsourceid = <LS_MAIL>
  AND (UTF8(payload) ILIKE '%parser%error%'
       OR UTF8(payload) ILIKE '%decompress%error%'
       OR UTF8(payload) ILIKE '%segmentation fault%'
       OR UTF8(payload) ILIKE '%unexpected%restart%')
GROUP BY qid
ORDER BY Totale DESC
LAST 24 HOURS
```

### Leggere il risultato

Confronta campione messaggi, aggiornamenti motore, crash e nuove connessioni. È un punto di partenza per exploit senza IOC noto.

### Limiti e falsi positivi

Errori e riavvii non dimostrano zero-day; serve riproduzione controllata/analisi vendor e evidenza di azioni successive.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: S03, G01

# Q101 / OpenBMC/IPMI: origini verso UDP 623

07 · Altri casi e controlli mirati / Intermedia / Basso

### Prerequisiti

Inventario BMC, firmware/OpenBMC reale e rete management.

```
SELECT sourceip, destinationip, COUNT(*) AS Righe,
       SUM(sourcebytes) AS ByteIn
FROM flows
WHERE destinationip = '<BMC_IP>'
  AND destinationport = 623 AND protocolid = 17
GROUP BY sourceip, destinationip
ORDER BY Righe DESC
LAST 24 HOURS
```

### Leggere il risultato

Per CVE-2021-39296 confronta accessi con jump host ammessi, audit BMC e cambi di configurazione.

### Limiti e falsi positivi

Porta IPMI non prova exploit. Un alert PKTSEARCH va verificato su contenuto pacchetti e versione.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: V10

# Q102 / Wing FTP: NUL codificato e log sessione

07 · Altri casi e controlli mirati / Avanzata / Alto

### Prerequisiti

HTTP/app log Wing FTP e, se presente, body della richiesta.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_WING>
  AND (UTF8(payload) ILIKE '%/loginok.html%'
       OR UTF8(payload) MATCHES '(?i).*username=[^ ]*%00.*'
       OR UTF8(payload) ILIKE '%os.execute%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

CVE-2025-47812: correla login, file sessione Lua e creazione di processo sotto il servizio FTP.

### Limiti e falsi positivi

NUL può non essere serializzato come %00; loginok è anche legittimo. Nessun hit non esclude exploit.

### Ridurre il lavoro di ricerca

Riduci prima l'insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l'output, non garantisce una scansione breve.

Riferimenti: V11

# Q103 / Pivot richieste e sessioni ZoneMinder

07 · Altri casi e controlli mirati / Intermedia / Alto

### Prerequisiti

Access/app log con versione e patch note.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_ZM>
  AND (UTF8(payload) ILIKE '%/zm/%'
       OR UTF8(payload) ILIKE '%ZMSESSID%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Correla endpoint, sessione, autenticazione ed eventuali errori del database.

### Limiti e falsi positivi

La sola famiglia di versione non identifica una CVE. Proteggi gli identificatori di sessione negli export.

### Ridurre il lavoro di ricerca

Mantieni fonte e finestra motivate; usa dettagli sui soli candidati. La riduzione dello scope deve essere documentata e non garantisce equivalenza dei risultati.

Riferimenti: G01, S03

# Q104 / Expressway: accessi al servizio di cluster

07 · Altri casi e controlli mirati / Avanzata / Basso

## Prerequisiti

Porta effettiva del servizio database/cluster dalla configurazione; inventario dei peer.

```
SELECT sourceip, destinationip, destinationport,
       COUNT(*) AS Righe, SUM(sourcebytes) AS ByteIn
FROM flows
WHERE destinationip = '<EXPRESSWAY_IP>'
  AND destinationport = <CLUSTER_PORT>
GROUP BY sourceip, destinationip, destinationport
ORDER BY Righe DESC
LAST 24 HOURS
```

## Leggere il risultato

Per CVE-2026-76466 cerca origini non peer e azioni root successive; controlla release e fix nel PSIRT del 21 ottobre.

## Limiti e falsi positivi

Non confondere Expressway con Webex o ESA. Questa è ricerca di esposizione/contatti, non firma RPC del PoC.

## Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: V12

# Q105 / FortiOS: errori del servizio e modifiche

07 · Altri casi e controlli mirati / Avanzata / Alto

### Prerequisiti

System/event log FortiOS, versione e servizio vulnerabile da confermare col PSIRT.

```
SELECT starttime, sourceip, destinationip, username,
       QIDNAME(qid) AS Evento, UTF8(payload) AS Raw
FROM events
WHERE logsourceid = <LS_FW>
  AND (UTF8(payload) ILIKE '%crash%'
       OR UTF8(payload) ILIKE '%config%changed%')
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

Per CVE-2025-25249 verifica applicability e telemetria del servizio; correla origini, nuove utenze e egress.

### Limiti e falsi positivi

Firma testuale esplorativa; il PSIRT non era leggibile direttamente nella ricerca, quindi non si fissano porte o versioni di remediation da questa query.

### Ridurre il lavoro di ricerca

Riduci prima l’insieme con tempo e logsourceid/host pertinenti. Per uso ripetuto valuta una proprietà estratta testata; confronta la copertura col raw. LIMIT contiene l’output, non garantisce una scansione breve.

Riferimenti: V13

# Q106 / Webex e porta 9000: verifica del contesto

07 · Altri casi e controlli mirati / Rapida / Basso

### Prerequisiti

Flussi e processo endpoint del client; verificare destinazioni e documentazione Webex corrente.

```
SELECT sourceip, destinationip, destinationport,
       PROTOCOLNAME(protocolid) AS Protocollo,
       SUM(sourcebytes) AS OutB,
       SUM(destinationbytes) AS InB
FROM flows
WHERE sourceip = '<HOST>' AND destinationport = 9000
GROUP BY sourceip, destinationip, destinationport,
         protocolid
LAST 60 MINUTES
```

### Leggere il risultato

Confronta il traffico con riunioni e processo firmato; usa questa come pivot sul esempio generico.

### Limiti e falsi positivi

La porta non identifica l’applicazione: nessun giudizio lecito/malevolo senza ulteriori elementi.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: G01, S07

# Q107 / SNMP e NetBIOS da un host

07 · Altri casi e controlli mirati / Rapida / Basso

### Prerequisiti

Flussi con protocollo e rete di provenienza noti.

```
SELECT destinationip, destinationport, protocolid,
       COUNT(*) AS Righe
FROM flows
WHERE sourceip = '<HOST>'
  AND destinationport IN (137,161)
GROUP BY destinationip, destinationport, protocolid
ORDER BY Righe DESC
LAST 60 MINUTES
```

### Leggere il risultato

Confronta monitoraggio inventario, stampanti, discovery e broadcast. Amplia con Q034 se molti host.

### Limiti e falsi positivi

Le porte 137/161 non provano scansione ostile; non cercare community SNMP dentro traffico non acquisito.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: G01, S07

# Q108 / Stessa sessione IdP da IP diversi

07 · Altri casi e controlli mirati / Avanzata / Medio

### Prerequisiti

ID sessione stabile/mascherato e IP client con catena proxy attendibile.

```
SELECT "Hunt_SessionID", "Hunt_TargetUser",
       UNIQUECOUNT(sourceip) AS Origini,
       SUM(eventcount) AS Eventi
FROM events
WHERE logsourceid = <LS_IDP>
  AND "Hunt_SessionID" IS NOT NULL
GROUP BY "Hunt_SessionID", "Hunt_TargetUser"
HAVING Origini > 1
ORDER BY Origini DESC
LIMIT 100 LAST 60 MINUTES
```

### Leggere il risultato

Verifica token/session replay con timeline, user-agent, device e cambi di rete legittimi.

### Limiti e falsi positivi

Mobile, VPN, reverse proxy e riuso di un ID non univoco producono falsi positivi; niente impossible travel senza posizione affidabile.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q109 / Regola WAF: riscontro con esito e path

07 · Altri casi e controlli mirati / Avanzata / Medio

### Prerequisiti

Custom Hunt_WAFRule string e dizionario esiti; request ID per approfondire il singolo hit.

```
SELECT "Hunt_WAFRule", "Hunt_Action",
       "Hunt_Status", "Hunt_URI", SUM(eventcount) AS N
FROM events
WHERE logsourceid = <LS_WEB>
  AND sourceip = '<IP>'
  AND "Hunt_WAFRule" IS NOT NULL
GROUP BY "Hunt_WAFRule", "Hunt_Action",
         "Hunt_Status", "Hunt_URI"
ORDER BY N DESC
LIMIT 100 LAST 60 MINUTES
```

### Leggere il risultato

Una regola con nome CVE è un segnale del sensore: confronta blocco, backend e azioni successive.

### Limiti e falsi positivi

Detection-only, false positive e rule revision cambiano significato; HTTP 200 non prova bypass.

### Ridurre il lavoro di ricerca

Conserva i filtri selettivi e raggruppa solo le dimensioni utili alla domanda. Recupera il raw in una seconda ricerca sui gruppi candidati; ridurre le dimensioni può cambiare il significato del risultato.

Riferimenti: S09

# Q110 / WSO2 VS Code: processi di test inattesi

07 · Altri casi e controlli mirati / Avanzata / Medio

### Prerequisiti

Telemetria processi EDR/Sysmon; Hunt_Image, Hunt_ParentImage e Hunt_CommandLine normalizzati a path Windows.

```
SELECT starttime, sourceip, username,
       "Hunt_Image", "Hunt_ParentImage",
       "Hunt_CommandLine", "Hunt_ProcessGuid"
FROM events
WHERE logsourceid = <LS_EDR>
  AND ("Hunt_ParentImage" ILIKE '%Code%'
       AND ("Hunt_Image" ILIKE '%cmd.exe'
            OR "Hunt_Image" ILIKE '%/sh'
            OR "Hunt_Image" ILIKE '%powershell.exe'))
ORDER BY starttime ASC
LIMIT 200 LAST 60 MINUTES
```

### Leggere il risultato

CVE-2026-19515 riguarda l’estensione Integrator MI, trust del workspace ed esecuzione test. Verifica progetto e versione estensione.

### Limiti e falsi positivi

Query ampia su sviluppo: molte shell sono normali. È un prodotto diverso da Identity Server e non dimostra accesso remoto al portale.

### Ridurre il lavoro di ricerca

Prova su 5 minuti con un evento noto, poi amplia. Mantieni il filtro esatto su campo normalizzato quando risponde alla stessa domanda; controlla gli indici effettivi e recupera il raw soltanto sui candidati.

Riferimenti: V09, S17

# Fonti

### S01 / IBM · Struttura ed esempi AQL

Indice web ufficiale; fetch diretto parzialmente 403.

www.ibm.com

### S02 / IBM · Esempi eventi e flussi

Esempi ufficiali; adattamento originale delle ricerche.

www.ibm.com

### S03 / IBM · Calcolo e formattazione

UTF8, DATEFORMAT, LONG; testo indicizzato ufficiale.

www.ibm.com

### S04 / IBM · Funzioni di recupero dati

INOFFENSE, OFFENSE_TIME e reference data; indicizzazione ufficiale.

www.ibm.com

### S05 / IBM · Aggregazioni AQL

COUNT, SUM, UNIQUECOUNT, STDEV e HAVING.

www.ibm.com

### S06 / IBM · Operatori AQL

TEXT SEARCH, ILIKE, MATCHES; documentazione ufficiale.

www.ibm.com

### S07 / IBM · Campi events e flows

Schema standard; verificare supporto del collector.

www.ibm.com

### S08 / IBM · Criteri temporali

LAST, START/STOP e millisecondi.

www.ibm.com

### S09 / IBM · Proprietà custom

Le proprietà Hunt_* di questo libro sono convenzioni locali da creare o rimappare.

www.ibm.com

### S10 / IBM · Monitoraggio utenti e rete

Esempi di aggregazioni per rete e identità.

www.ibm.com

### S11 / IBM · Sottoquery AQL

FROM e IN; una colonna IN e massimo 10.000 risultati interni.

www.ibm.com

### S12 / IBM · Prestazioni filtri testuali

Case sensitivity e costo relativo; evitare equivalenze universali.

www.ibm.com

### S13 / IBM · Release 7.5 UP11

Esempio di fix su reference map ed eventi offense: conta la build.

www.ibm.com

### S14 / IBM · Events FAQ / coalescing

Coalescenza, conteggi e raw rappresentativi.

www.ibm.com

### S15 / Microsoft · Windows Security events

Catalogo dei tipi di evento; query AQL originali, non query Sentinel copiate.

learn.microsoft.com

### S16 / Microsoft · Exchange hybrid security

Articolo Exchange Team aggiornato il 7 maggio 2026.

techcommunity.microsoft.com

### S17 / Microsoft · Sysmon

Telemetria processi, file e ProcessAccess; policy e configurazione determinano copertura.

learn.microsoft.com

### S18 / IBM · Esempi reference data

Consultato come riferimento aggiuntivo; verificare disponibilità in 7.5.

www.ibm.com

### S19 / IBM · Logica condizionale

IF/CASE nel motore AQL; comportamento dei report da validare separatamente.

www.ibm.com

### S20 / IBM · GLOBALVIEW

Accesso a saved search accumulate; dipendenza dallo schema della vista.

www.ibm.com

### S21 / IBM · API POST Ariel searches

Ricerca asincrona; versione API da adattare alla console.

ibmsecuritydocs.github.io

### S22 / IBM · API stato e risultati

Reference endpoint; non è una prescrizione della versione API 15.

ibmsecuritydocs.github.io

### S23 / IBM · Event processing performance

Ottimizzazione delle proprietà e pipeline.

www.ibm.com

### S24 / IBM · Ricerche offense lente

Indici dominio/offense e limiti delle ricerche correlate.

www.ibm.com

### V01 / WSO2 · CVE-2022-29464

Advisory originale WSO2; Identity Server 5.8.0 elencato.

security.docs.wso2.com

### V02 / NIST NVD · CVE-2022-29464

Dettagli fileupload e traversal; rimandi a exploit e KEV.

nvd.nist.gov

### V03 / WSO2 · SCIM authorization

Advisory che indica 5.8.0 o superiore come non affetto da quel problema specifico.

security.docs.wso2.com

### V04 / Cisco · CVE-2025-20393

Advisory letto; HTTP Spam Quarantine, RCE root e release corrette.

sec.cloudapps.cisco.com

### V05 / Citrix · CTX697096

CVE-2026-88771/88772 e altre; testo vendor letto, sfruttamento osservato dichiarato.

support.citrix.com

### V06 / CERT-EU · Exchange CVE-2025-53786

Advisory istituzionale e collegamenti Microsoft; richiede admin on-prem.

cert.europa.eu

### V07 / WSO2 · CVE-2026-5430

Pubblicato 3 maggio 2026; bypass JWT su prodotti/versioni esplicitamente elencati.

security.docs.wso2.com

### V08 / WSO2 · CVE-2026-4249

Pubblicato 3 maggio 2026; DoS persistente nel throttling.

security.docs.wso2.com

### V09 / WSO2 · CVE-2026-19515

Pubblicato 15 settembre 2026; estensione MI VS Code, non Identity Server.

security.docs.wso2.com

### V10 / Google Security Research · OpenBMC

Ricerca originale CVE-2021-39296 con PoC pubblico; non eseguito.

github.com

### V11 / RCE Security · Wing FTP

Ricerca originale CVE-2025-47812 con dettagli e PoC; non eseguito.

www.rcesecurity.com

### V12 / Cisco · CVE-2026-76466

21 ottobre 2026; Expressway cluster, RPC/cookie e comandi root.

sec.cloudapps.cisco.com

### V13 / NHS England · Fortinet CC-4736

Advisory istituzionale con aggiornamento 9 settembre 2026; PSIRT FG-IR-25-084 non leggibile direttamente.

digital.nhs.uk

### V14 / NIST NVD · Outlook CVE-2026-78509

Solo record indicizzato leggibile: heap overflow Outlook. Fetch diretto senza testo; MSRC richiede JavaScript.

nvd.nist.gov

### V15 / Microsoft MSRC · CVE-2026-78509

Pagina individuata ma dettagli non leggibili: non usata per affermare PoC, zero-click o sfruttamento.

msrc.microsoft.com

### P01 / IBM - Index Management 7.5

Indici come filtro dei dati e costo di spazio; testo ufficiale indicizzato.

www.ibm.com

### P02 / IBM - Indexing best practices

Indici delle proprietà e dati storici; contesto documentale Advisor.

www.ibm.com

### P03 / IBM - Event processing performance

Parsing, proprietà e cardinalità delle global view.

www.ibm.com

### P04 / IBM - AQL subquery

Dipendenze tra subquery e query esterna; limite dei risultati IN.

www.ibm.com

### P05 / IBM - Search status API

Stati, processed_record_count, record_count e query_execution_time; verificare unità e campi nella API locale.

ibmsecuritydocs.github.io

### P06 / IBM - AQL retrieval functions

OFFENSE_TIME, reference data, GLOBALVIEW e scope dei processor.

www.ibm.com

### P07 / IBM - Resource restrictions

I nodi distribuiti e il trasferimento dei risultati possono influire sulla ricerca; testo indicizzato.

www.ibm.com

### P08 / IBM - AQL logical/comparison operators

LIMIT e vincoli TEXT SEARCH; riferimento della sintassi.

www.ibm.com

### P09 / IBM - Indexed properties and Quick Filters

Supporto IBM per indicizzazione e ricerca testuale.

www.ibm.com

## P10 / IBM - Globalview database

Accesso alle viste accumulate tramite API e schema della saved search.

www.ibm.com

## G01 / Scenario didattico generico

Esempio ipotetico con parametri e indirizzi di documentazione; nessun incidente reale o indicatore verificato.